1과목 : 시스템 보안

1. 다음 인증관리방법에 해당하는 것은?

> 다수의 서버가 존재하는 업무환경에서 하나의 시스템에 인증을 성공하게 되면 다른 시스템에 대한 접근 권한을 얻게 되도록 하는 통합인증 시스템

① PAM ② OTP
③ 계정 접속관리(IAM 등) ④ SSO

<문제 해설>
SSO(Single Sign On)
한 번의 로그인으로 여러 개의 서비스들을 이용할 수 있게 해주는 시스템
[해설작성자 : 웅냠]

2. 다음 중 리눅스에서 Process ID(PID) 1번을 가지고 있는 프로세스는 무엇인가?

① init ② 부트로더
③ OS 커널 ④ BIOS

<문제 해설>
PID는 프로세스 고유 번호이다..init 프로세스는 모든 프로세스의 부모이다.
1) 리눅스 커널 부팅 후
2) init 프로세스가 실행된 후
3) 다른 프로세스가 실행된다..
[해설작성자 : Barro]

3. 사용자의 고유한 ID에 해당되는 필드는?



① ①번 필드 ② ②번 필드
③ ③번 필드 ④ ④번 필드

<문제 해설>
아래와 같은 오류 신고가 있었습니다.
여러분들의 많은 의견 부탁 드립니다.
추후 여러분들의 의견을 반영하여 정답을 수정하도록 하겠습니다.
참고로 정답 변경은 오류 신고 5회 이상일 경우 수정합니다.

[오류 신고 내용]
① Operating System : 윈도우 시스템을 의미
② System Type : 시스템이 도메인 컨트롤러 이거나 단독 시스템(stand-alone)임을 의미
③ System Number : 해당 시스템만의 고유 식별자로 윈도우를 재설치하면 값이 변화됨
④ UID : 사용자 식별자(ID)로 500(Administrator), 501(Guest), 1000이상(일반사용자)
[해설작성자 : comcbt.com 이용자]

[오류신고 반론]
알기사 198번 문제 참조하여 전문을 기재합니다.
[다음은 윈도우 서버에서 Administrator 계정의 SID(Security Identifier)를 나타내고 있다..숫자로 표현되는 각 사용자의 고유한 ID에 해당되는 필드는?]

4번은 각 사용자의 RID(relative ID) 로 관리자는 500, guest 계정은 501번, 일반사용자는 1000번 이상의 숫자를 나타냄으로써 사용자를 식별할 수 있게한 상대적 id 값입니다.
사용자의 고유한 id 를 물었으니 맥락상 3번이 맞습니다..고유한 id 값을 선택하라는 문제에 사용자 식별자 값을 정답으로 선택하기엔 어려움이 있죠.
[해설작성자 : 호감고닉미다]

[추가 오류 신고]
반론 : 답은 4번 같습니다.

"S-1-5-21-3623811015-3361044348-30300820-1013"과 같은 SID는 다음을 나타냅니다:

S-1- : SID 헤더
5 : Windows의 표준 SID 버전 번호
21-3623811015-3361044348-30300820 : 도메인 식별자
1013 : 리소스 식별자 (해당 사용자, 그룹 또는 컴퓨터의 고유 식별자)
[해설작성자 : nico1006]

[추가 오류 신고]
앞 내용계속...
S-1- : SID를 식별하는 헤더입니다..모든 SID는 "S-1-"로 시작합니다.
도메인 식별자: 사용자, 그룹 또는 컴퓨터가 속한 도메인의 고유 식별자입니다.
리소스 식별자: 도메인 내에서 사용자, 그룹 또는 컴퓨터의 고유 식별자입니다.
[해설작성자 : nico1006]

[오류신고 반론]
admin 500은 모든 윈도우 시스템에서 동일한 RID로 나타납니다..전역적 고유성은 3번필드가 맞습니다.

4. SetUID와 SetGID가 설정된 모든 파일을 찾으려는 명령어가 바르게 기술된 것은?

① find / -type f ₩(-perm -1000 -0 perm -2000 ₩) -print
② find / -type f ₩(-perm -2000 -0 perm -4000 ₩) -print
③ find / -type f ₩(-perm -100 -0 perm -200 ₩) -print
④ find / -type f ₩(-perm -200 -0 perm -400 ₩) -print

<문제 해설>

find는 주어진 조건을 검색하여 파일을 찾는 명령어
setUid = 4000
setGid = 2000
[해설작성자 : 웅냠]

5. 다음 지문에서 설명하고 있는 보안 기술은 무엇인가?

> - 동일한 패스워드를 사용하는 보안상의 취약점을 극복하여 일회성의 서로 다른 패스워드를 생성하게 함으로써 안전한 자상거래를 진행한다.
> - 온라인 뱅킹, 전자상거래, 온라인 게임, 기업 네트워크 등에서 사용한다.
> - 하드웨어적 또는 소프트웨어적으로 구현 가능하다.

① 스마트토큰
② OTP(One-Time Pad)
③ OTP(One-Time Password)
④ 보안카드

<문제 해설>
일회성 비밀번호 = OTP(One Time Password)
[해설작성자 : 웅냠]

6. 다음 지문에 (㉠)에 들어갈 용어로 올바른 것은?

> (㉠)은(는) 프로그램이 실행되면서 동적 할당하여 사용되는 메모리 영역이다. 개발자가 malloc과 같은 메모리 할당 함수를 이용해 프로그램을 개발하였다면, (㉠) 영역을 오버플로우 시켜 특정 코드를 실행하도록 하는 공격이 가능하다.

① 스택(Stack)
② 힙(Heap)
③ 버퍼(Buffer)
④ 스풀(Spool)

<문제 해설>
heap
- 컴퓨터에서 일부분이 프로그램에 할당되고 회수되는 영역
- 동적 메모리 할당을 위해서 프로그래머가 할당 및 해제를 해줘야함

heap buffer over flow
- 선언된 크기보다 더 큰 데이터를 기록해서 발생되는 현상
- 힙영역에 위치한 임의의 데이터나 포인터 기록 및 실행을 허용함으로써 발생
[해설작성자 : 한비로]

스택 (Stack): 지역 변수 / 함수 호출 및 복귀 /후입선출(LIFO) 구조
힙 (Heap): 동적 할당 메모리 / 자유 저장소 / 사용자 관리
버퍼 (Buffer): 메모리 영역/ 데이터 저장 /오버플로우 취약점
스풀 (Spool): 출력 대기열 / 프린터 관리 / 데이터 버퍼링
[해설작성자 : nico1006]

7. 취약점 점검용으로 사용되는 도구가 아닌것은?

① SATAN
② Nessus
③ Snort
④ ISS

<문제 해설>
1. 원격으로 취약점 점검
2. 클라이언트 취약점 점검
3. 네트워크 침입탐지 시스템
4. 상업적 스캐닝 도구
[해설작성자 : AB6IX 박우진]

취약점 점검도구
- SATAN/SARA
- SAINT
- OOPS
- Nessus
- nmap
- ISS(Internet Security Scanner)
[해설작성자 : Codedtree]

8. 이메일과 관련된 프로토콜이 아닌것은?

① SMTP
② SNMP
③ POP3
④ IMAP

<문제 해설>
SNMP(Simple Network Management Protocol)
네트워크 관련 프로토콜
[해설작성자 : 웅냠]

9. 트로이목마의 특징이 아닌 것은?

① 백도어(Back Door)로 사용할 수 있다.
② 자기복제 능력이 있다.
③ 유용한 프로그램에 내장되어 배포될 수 있다.
④ 정보유출이나 자료파괴 같은 피해를 입힐 수 있다.

<문제 해설>
트로이목마(Trojan Horse)
트로이 전쟁 이야기에서 유래됨

특징
- 트로이목마 = 자기복제 능력이 없음
>> 컴퓨터 바이러스 = 자기복제능력 및 부작용을 일으킴
[해설작성자 : 한비로]

10. 다음 지문은 무엇을 설명한 것인가?

> 일반 프로그램에 악의적인 루틴을 추가하여 그 프로그램을 사용할 때 본래의 기능 이외에 악의적인 기능까지 은밀히 수 행하도록 하는 공격을 말한다. 예를들어 사용자 암호를 도출 하기 위해서 합법적인 로그인(login) 프로그램으로 가장하고 정상적인 로그인 순서와 대화를 모방하여 작성될 수 있다.

① 트로이목마(Netbus)
② 매크로 바이러스(Macro virus)
③ 웜(I-Worm/Hybris)
④ 악성 스크립트(mIRC)

<문제 해설>
트로이 목마
일반 프로그램에 악의적인 루틴을 추가하여 그 프로그램을 사용할 때 본래의 기능외 악의적인 기능까지 은밀히 수행하도록 하는 공격을 의미, 자기복제능력이 엇고 악성코드를 전파하지 않음

바이러스
다른 독립적인 프로그램의 코드내에 스스로를 주입한다음 악성행동을하고 확산하는 프로그램코드,
예시로 부트바이러스, 매크로 바이러스, 모바일 바이러스가 있음
>> 매크로바이러스 : 소프트웨어(Excel, word 등)의 매크로 기능을 악용한 바이러스, 누구나 쉽게 바이러스 제작이 가능

웜
다른파일에 기생하지 않으며 네트워크 등의 연결을 통하여 자신의 복제품을 전파하며 독립적으로 실행됨

악성 스크립트(mIRC)
멀웨어 개발자가 mIRC 프로그램의 기능을 이용하여 채널에 접속하면 특정 사이트를 홍보하는 글을 출력 하거나, 또는 mIRC를 이용해서 바이러스를 유포한다.
[해설작성자 : 맞나?아닌가?]

짧게....
트로이목마 (Netbus): 원격 제어 도구 / 몰래 설치/ 백도어
매크로 바이러스 (Macro virus): 문서 내 매크로 사용/ 자동 실행/ 보안 취약점
웜 (I-Worm/Hybris): 네트워크 전파 / 자기 복제 / 이메일 첨부 파일
악성 스크립트 (mIRC): 채팅 클라이언트 / 스크립트 실행/ 백도어 및 악의적 기능
[해설작성자 : nico1006]

11. xfile(파일)에 대한 접근권한을 숫자로 올바르게 표현한 것은?

```
-r-s-wsrwt 1 root root 11 11월 8 13:11 xfile
```

① 6426 ② 7537
③ 1537 ④ 1426

<문제 해설>
setUid = 4000
setGid = 2000
sticky bit = 1000
setUid+setGid+sticky bit = 7000

-r-s 4+1=5
-ws 2+1=3
rwt 4+2+1=7

7537
[해설작성자 : AB6IX 박우진]

12. 다음 중 악성코드의 치료 방법이 다른 것은?

① 바이러스 ② 웜
③ 트로이목마 ④ 스파이웨어

<문제 해설>
바이러스, 웜, 트로이목마는 백신프로그램으로 치료가 가능하나 스파이웨어 유일한 치료법은 사용자 데이터를 백업하고 운영 체제를 완전히 다시 설치하는 것입니다
[해설작성자 : 웅냠]

바이러스:
- 백신 소프트웨어 사용
- 감염된 파일을 격리하고 삭제
- 시스템을 스캔하여 모든 바이러스를 제거

웜:
- 방화벽 설정 강화
- 최신 보안 패치 및 업데이트 적용
- 감염된 시스템에서 웜 프로그램 제거 및 시스템 재설정

트로이목마:
- 백신 소프트웨어 및 알고리즘을 사용하여 감지 및 제거
- 감염된 파일과 프로세스를 식별하여 삭제
- 시스템 및 네트워크 보안 강화

스파이웨어:
- 안티스파이웨어 소프트웨어 사용
- 감염된 컴퓨터에서 스파이웨어를 제거하고 시스템 정리
- 온라인 활동 시 주의하고, 팝업 창 및 알 수 없는 링크를 클릭하지 않도록 주의력을 기울임
[해설작성자 : comcbt.com 이용자]

13. 윈도우 시스템에서 사용자 계정과 패스워드 인증을 위해 서버나 도메인 컨트롤러에 증명하는 Challenge & Response 기반의 인증 프로토콜은?

① LSA ② SAM
③ NTLM ④ SRM

<문제 해설>
NTLM (NT LAN Manager)
- NTLM 은 윈도우에서 제공되는 인증 프로토콜
- Challenge-Response(도전-응답) 라고 불리는 인증 프로토콜 방식을 사용
- 최근, 거의 쓰이지 않고 있으며 MS 에서도 사용을 권장하지 않고있다..
아직 로컬 환경에서 쓰일 수 있으며 SMB 프로토콜에도 하위호환성을 위해 내장
[해설작성자 : 한비로 두비로 세비로]

NTLM은 보안 취약점이 있어서 현재는 더 안전한 프로토콜인 Kerberos나
최신의 인증 방법인 (NTLM을 보완한) NTLMv2 등으로 대체되는 추세.

[해설작성자 : nico1006]

14. 다음 중 컴퓨터 바이러스에 대한 설명으로 옳지 않은 것은

① 부트 바이러스란 플로피디스크나 하드디스크의 부트섹터를 감염시키는 바이러스를 말한다.
② 파일 바이러스는 숙주 없이 독자적으로 자신을 복제해 다른 시스템을 자동으로 감염시켜 자료를 유출, 변조, 삭제하거나 시스템을 파괴한다.
③ 이메일 또는 프로그램 등의 숙주를 통해 전염되어 자료를 변조, 삭제하거나 시스템을 파괴한다.
④ 최근 들어 암호화 기법을 기반으로 구현된 코드를 감염시마다 변화시킴으로써 특징을 찾기 어렵게 하는 다형성(Polymorphic) 바이러스로 발전하고 있다.

<문제 해설>
컴퓨터 웜(영어: computer worm)
스스로를 복제하는 악성 소프트웨어 컴퓨터 프로그램이다..컴퓨터 바이러스와 비슷하다.
바이러스가 다른 실행 프로그램에 기생하여 실행되는 데 반해 웜은 독자적으로 실행되며 다른 실행 프로그램이 필요하지 않다.
[해설작성자 : 한비로 두비로 세비로]

15. 다음 중 C언어 함수 중에서 버퍼 오버플로우 취약점이 발생하지 안도록 하기 위해 권장하는 함수가 아닌 것은?

① strncat() ② strncpy()
③ snprintf( ) ④ gets()

<문제 해설>
프로그램을 컴파일할 때 검사하여 버퍼 오버플로우를 방지하거나 발견하는 것을 목표로 한다.
가장 기본적인 대응책은 버퍼 오버플로우를 허용하지 않는 Java, ADA, Python과 같은 현대화된 고급 프로그래밍 언어를 사용하여 소프트웨어를 작성

사용 자제를 권장하는 함수 : strcat(), strcpy(), get(), scanf(), sscanf(), vscanf(), vsscanf(), sprintf(), vsprintf(), gethostbyname(), realpath()

사용을 권장하는 함수 : strncat(), strncpy(), fgets(), fscanf(), vfscanf(), snprintf(), vsnprintf()
[해설작성자 : 한비로 두비로 세비로]

16. net 명령어에 대한 설명으로 잘못된 것은?

① net share : 서버의 모든 공유 리소스 확인 또는 제거
② net user : 서버의 사용자 계정 확인 및 관리
③ net session : 서버에 현재 원격 로그인된 사용자 확인 또는 세션종료
④ net computer : 서버에서 실행하고 있는 서비스 확인 또는 특정 서비스 실행

<문제 해설>
net share : 공유 자원을 설정할 수 있는 명령어
net user : 사용자계정 생성·삭제·관리
net session : 서버에 있는 사용자 이름, 열린 파일이 있는지 여부 및 각 유휴 시간을 알 수 있는 명령어
net computer : 컴퓨터를 도메인에 추가하거나 삭제할 수 있는 명령어
[해설작성자 : 맞나?아닌가?]

17. 다음 중 윈도우 운영체제에서 사용하는 파일 시스템이 아닌 것은?

① FAT16 ② FAT32
③ EXT3 ④ NTFS

<문제 해설>
Windows 파일시스템
1. FAT : DOS시절 사용되던 파일시스템
- FAT16
- FAT32
2. NTFS : FAT을 보완하기위해 만들어짐
[해설작성자 : 맞나?아닌가?]

18. 다음 중 Telnet 보안에 대한 설명 중 틀린 것은?

① TELNET 세션은 암호화 및 무결성 검사를 지원하지 않는다.
② SSH(Secure Shell)는 암호화를 하지 않는다.
③ 패스워드가 암호화되어 있지 않아 스니퍼를 이용하여 제3자에게 노출 될 수 있다.
④ UNIX 시스템에서 해커가 in.telnetd를 수정하여 클라이언트의 특정 터미널 종류에 대해 인증과정 없이 쉘을 부여할 수도 있다.

<문제 해설>
telnet : 사용자가 네트워크를 연결하여 그 컴퓨터에서 제공하는 서비스를 이용할 수 있게함
평문통신을 한다.
ssh : SSH는 다른 사용자가 세션을 가로채지 못하도록 세션을 감싼다.
>>> telnet는 정보를 byte스트림형식으로 주고받고, ssh는 DES,RSA 등 암호화를 통해 통신
[해설작성자 : 한비로 두비로 세비로]

19. 유닉스 시스템 명령어는?

> 시스템의 파일 또는 레터리가 만들어질 때의허가권의 기본값을 지정하기 위해서 사용한다. 해당 설정은 모든 계정 사용자들에게 존재하는 값으로서 각 계정 사용자들이 생성하는 파일 또는 디렉터리의 허가권을 결정하기 위한 값이다.

① chmod ② umask
③ chown ④ touch

<문제 해설>
chmod
- 권한설정을 위한 명령어

umask
- 새 폴더, 새 파일의 퍼미션을 결정하는 값, 또는 설정 명령어
- 기본 umask값은 0022

chown
- 소유자, 그룹변경을 위한 명령어

touch
- 파일을 생성하거나 갱신하는 명령어
[해설작성자 : 한비로 두비로 세비로]

20. 분석 시 사용될 수 있는 명령어에 대하여 잘못 나열한 것은?

① secure - 사용자 원격접속 정보 - text file - grep
② utmp - 현재 로그인 사용자 정보 - binary file - who
③ pacct - 사용자별 명령 실행 정보 - text file - history
④ wtmp - 최근 로그인 및 접속 호스트 정보 - binary file- last

<문제 해설>
pacct- 사용자별 명령어 실행 정보 가진 파일
- 명령어 : lastcomm
[해설작성자 : jjh]

pacct 파일을 분석할 때 사용하는 명령어
1. lastcomm : 사용자별, 프로세스별 실행된 명령어 보여줌
2. ac : 사용자별 또는 특정시간 간격별 사용량 보여줌
3. dump-acct : pacct 파일의 내용을 읽어 사용량을 텍스트 형식으로 출력
4. sa : pacct 파일로부터 시스템 사용량 통계 및 보고서 생성.
[해설작성자 : nico1006]

2과목 : 네트워크 보안

21. 내부 네트워크와 외부 네트워크 사이에 위치하여 외부에서의 침입을 1차로 방어해 주며 불법 사용자의 침입차단을 한 정책과 이를 지원하는 소프트웨어 및 하드웨어를 제공 는 것은?

① IDS(Intrusion Detection System)
② Firewall
③ Bridge
④ Gateway

<문제 해설>
방화벽 : 외부로 부터 내부 네트워크의 정보와 자원을 불법적인 침입으로부터 보호하기 위한 접근제어 시스템, 이를 지원하는 하드웨어와 소프트웨어를 총칭함
[해설작성자 : 한비로 두비로 세비로]

22. VPN(Virtual Private Network)의 보안적 기술 요소와 거리가 먼 것은?

① 터널링 기술 : 공중망에서 전용선과 같은 보안 효과를 얻기 위한 기술
② 침입탐지 기술 : 서버에 대한 침입을 판단하여 서버의 접근제어를 하는 기술
③ 인증 기술 : 접속 요청자의 적합성을 판단하기 위한 인증기술
④ 암호 기술 : 데이터에 대한 기밀성과 무결성을 제공하기 위해 사용되는 암호 알고리즘 적용 기술

<문제 해설>
VPN
인터넷과 네트워크를 마치 전용 회선처럼 사용할 수 있게 함

-데이터 암호화 및 사용자인증, 사용자 권한 제한 제공
-터널링을 통한 가상경로를 설정해 통신서비스 제공

>>vpn에는 침입탐지 기술이 없어,IDS제품을 통합하여 같이이용하는 방식으로 이용함
[해설작성자 : 한비로]

23. 다음은 DOS 창에서 어떤 명령어를 실행시킨 결과인가?

```
C:WDocuments and SettingswAdministrator>( )
203.252.53.47 203.252.53.47 with 32 bytes of
data:
Reply from 203.25253.47: bytes=32 time<1ms
TTL=128
Reply from 203.252.53.47: bytes=32 time<1ms
TTL=128
Reply from 203.252.53.47: bytes=32 time<1ms
TTL=128
Reply from 203.252.53.47: bytes=32 time<1ms
TTL=128
statistics for 203.252.53.47 | Packets: Sent =
4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
Minimum = Oms, Maximum = Oms, Average =
Oms
```

① ping ② traceroute
③ date ④ netstat

<문제 해설>
해당 보기는 PING에대한 내용이다

예시 >>>
C:₩>ping 8.8.8.8
Ping 8.8.8.8 32바이트 데이터 사용:
8.8.8.8의 응답: 바이트=32 시간=38ms TTL=116
8.8.8.8의 응답: 바이트=32 시간=38ms TTL=116
8.8.8.8의 응답: 바이트=32 시간=38ms TTL=116
8.8.8.8의 응답: 바이트=32 시간=39ms TTL=116

8.8.8.8에 대한 Ping 통계:
패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
왕복 시간(밀리초):
최소 = 38ms, 최대 = 39ms, 평균 = 38ms
[해설작성자 : 한비로]

24. 다음 지문에서 설명하고 있는 침입차단시스템은?

외부 네트워크와 내부 네트워크 사이에 하나 이상의 경계 네트워크를 두어 내부 네트워크를 외부 네트워크로부터 분리하기 의 한 구조이다. 비무장지대(DMZ)라고 불리는 경계 네트워크에는 서비스를 위해 외부에서 접속이 많은 시스템을 구성하고 보호할 정보가 많은 시스템은 내부 네트워크 안에 구성한다.

① 스크리닝 라우터(Screening Router)
② 스크린된 호스트 게이트웨이(Screened Host Gateway)
③ 이중 홈 게이트웨이(Dual-homed Gateway)
④ 스크린된 서브넷 게이트웨이(Screened Subnet Gateway)

<문제 해설>
1.스크리닝 라우터(Screening router)
- 외부(인터넷)과 내부망의 가운데에서 [패킷필터링] 규칙을 적용해서 방화벽의 역할을 수행하는 구조

2. 스크린된 호스트 게이트웨이(Screened Host Gateway)
- 스크린이란 즉, '숨겨진' 이라는 뜻으로 방화벽이 숨겨져 있다는 뜻
- 스크리닝 라우터와 단일 혹은 듀얼 홈 게이트웨이와 조합해서 사용하는 방식(비쌈)

3.이중 홈 게이트웨이(Dual-Homed Gateway)
- 이중 홈 게이트웨이는 네트워크 카드가 두개이상 갖춰져있는 방화벽
- 하나는 내부, 또 하나는 외부망에 대해 각각 운영
- 내부에서 외부로 갈려면 반드시 이중 홈 게이트웨이를 지나가야 하므로 좀 더 효율적으로 트래픽을 관리

4. 스크린된 서브넷 게이트웨이(Screened Subnet Gateway)
- 외부와 내부의 가운데에 DMZ(DeMilitarized Zone)를 위치시켜 완충지대를 구성(프록시 구성)
- 방화벽들의 장점을 모두 갖고 있으며 상당히 안전한 편(비용이 많이 비쌈)
[해설작성자 : 한비로]

25. 다음 중 TCP 프로토콜을 사용하여 서버와 클라이언트가 통신을 수행할 때 서버에서 클라이언트의 접속요청을 기다리는 함수명은?

① bind()　② connect()
③ listen()　④ accept()

<문제 해설>
socket() : tcp나 udp 통신을 하기 위해 사용
connet() : 서버로 연결
send() : 데이터 전송
bind() : 소켓과 포트번호를 결합시켜주는 것
listen() : 클라이언트 요청을 대기시킬 수신 대기열
accept() : 수신 대기열에 있는 클라이언트의 연결 요청을 확인
send() : 요청에 대해 응답
close() : 소켓을 통신 종료(할당된 자원 회수)
[해설작성자 : 한비로]

26. 다음 설명에 해당하는 서비스거부(DoS) 공격은?

헤더가 조작된 일련의 IP 패킷조각(IP Fregments)들을 전송함으 로써 공격이 이루어지며 공격자는 데이터의 일부가 겹치거다. 일부 데이터를 포함하지 않는 패킷 조각들을 전송함으로써 패 킷 재조합 시 공격대상에서 부하를 발생시키는 공격 유형이다.

① Teardrop　② Land attack
③ Syn Flooding　④ Smurf attack

<문제 해설>
Teardrop
IP 패킷의 fragment offset 값을 서로 중첩되도록 조작하여 전송하고
IP패킷의 재조합과정에서 오류가 발생하여 시스템 기능을 마비시키는 공격

Land attack (Local Area Network Denial Attack)
IP스푸핑을 이용한 공격
네트워크 패킷의 출발지 IP를 변조해 공격 대상의 자원을 소모시킴
공격자가 피해자에게 네트워크 패킷을 보낼 때 패킷의 출발지와 도착지의 IP를 피해자의 IP로 동일하게 하는 것
계속 반복되면 네트워크에 과부하가 걸리게 된다.
[해설작성자 : 맞나?아닌가?]

3.Syn Flooding
TCP/IP 취약성을 이용한 서비스거부(Dos)공격 방식 중 하나이다..
TCP/IP 네트워크는 3-Way-Handshake 과정을 통해 클라이언트가 원격지 서버와 연결을 시도하고,
원격서버에서 보내온 응답 문자에 응답한 후 연결이 이루어 진다.
그러나 클라이언트에 ACK응답이 없으면 서버는 클라이언트 접속 정보를 log에 쌓아 두는데 이러한 요구가
증가했을 경우 시스템은 운용 기록 공간을 충분히 확보 하지 못하고 결국 네트워크 중단으로 이어져 서비스
거부가 일어난다.

4.Smurf attack
출발지IP를 희생자IP로 위조한 후 희생자의 네트워크가 연결된 브로드캐스트로 ICMP ECHO REQUEST를 보냄.
해당 네트워크에 연결된 모든 시스템은 위조된 희생자의 IP에서 수신한 것으로 알고 ICMP ECHO REQUEST에 응답을 하여
ICMP ECHO Reply를 희생자IP로 전달. 희생자는 트래픽 과부하로 서비스 거부를 유발시키는 공격기법이다.
[해설작성자 : 해설을 보세요]

27. 다음지문에서 설명하는 침입 탐지 관련 판정은?

공격자가 실제로 시스템에 침입하였으나 침입탐지 시스템은 이를 정상적인 동작으로 인식하여 침입을 제대로 탐지 못한 경우의 판정

① True Positive ② False Positive
③ True Negative ④ False Negative

<문제 해설>
false positive : 오류가 존재하지않지만 오류라고 판정
false negative : 오류가 존재하지만 오류가 없다고 판정
[해설작성자 : 한비로]

true positive : 내가 양성인데 의사가 양성이라고 판단.
-> 바이러스를 바이러스 맞다고 맞게 판단.
true negative : 내가 음성인데 의사가 음성이라고 판단.
-> 바이러스 아닌데 , 바이러스 아니라고 맞게 판단.

false positive : 내가 음성인데 의사가 양성이라고 판단.
-> 바이러스 아닌데, 바이러스 맞다고 판단, 오탐 (잘못 탐지)
false negative : 내가 양성인데 의사가 음성이라고 판단.
-> 바이러스를 바이러스 아니라고 판단, 미탐 (탐지 못함)
[해설작성자 : 살려줘]

28. 다음 보기에서 설명하고 있는 공격에 대한 방식은?

ICMP Echo Request 패킷의 크기를 정상적인 크기보다 크게 만들어 공격 대상 네트워크에 송신하고 네트워크를 통해 라우팅되어 공격 대상 네트워크에 도달하는 과정에서 작은 조각(Fragment)들로 분할된다.

① Teardrop 공격
② Ping of Death 공격
③ UDP Traffic Flooding 공격
④ Tiny Fragmentation 공격

<문제 해설>
죽음의 핑(Ping of Death)
해킹 기법 중 하나, 규정 크기 이상의 ICMP 패킷으로 시스템을 마비시키는 공격
[해설작성자 : 맞나?아닌가?]

29. 다음 중 방화벽의 기능이 아닌 것은?

① 접근제어
② 인증
③ 로깅 및 감사추적
④ 침입자의 역추적

<문제 해설>
방화벽의 주요기능
1. 접근제어
- 구현방법에 따라 패킷 필터링, 프록시 방식으로나눔
2. 로깅과 감사추적
- 룰셋, 관리자접근, 네트워크 트래픽 허용 등의 로그
3. 인증
- 메세지 인증 : VPN같은 신뢰된 통신선을 이용한것을 신뢰
- 사용자 인증 : 패스워드, OTP, 토큰 등의 인증
- 클라이언트 인증 : 모바일사용자처럼 특수한 접속을 요구하는 호스트 확인법
[해설작성자 : 한비로]

30. 다음 중 무선랜 구축 시 보안 고려사항으로 가장 적합하지 않은 선택은 무엇인가?

① SSID를 숨김모드로 사용
② 관리자용 초기 ID/Password 변경
③ 무선 단말기의 MAC 주소 인증 수행
④ 보안성이 우수한 WEP(Wired Equivalent Privacy) 사용

<문제 해설>
무선랜 인증 및 데이터 보안

SSID는 무선랜 서비스 영역을 식별하기 위해 사용되는 ID
무선 AP는 출고 시 기본적으로 해당 장비의 이름으로 설정되어 나온다.
변경하지 않고 사용할 경우 장비의 취약점, 설정 값을 공격에 이용할 수 있다.

관리자 페이지는 초기 사용자 편의를 위해 패스워드가 없거나 기본으로 설정되어 출고된다.

허가된 고정IP와 고유하게 부여된 MAC 주소로만 접근 제어를 수행한다.

WEP(Wired Equivalent Privacy)는 상대적으로 보안 기능이 취약합니다..
따라서 무선 데이터의 보호 효과를 높이기 위해 WPA, WPA2 등과 같은 다른 방법을 사용합니다.
[해설작성자 : 한비로]

31. 다음에서 호스트기반 침입탐지시스템(HIDS : host-based IDS)에 의해서 처리되는 이상행위의 유형이 아닌 것은?

① 프로토콜 이상행위(Protocol Anomaly)
② 버퍼오버플로우 취약점 공격(Buffer Overflow Exploits)
③ 권한 확대 취약점 공격(Privilege-escalation Exploits)
④ 디렉터리 검색(Directory Traversal)

<문제 해설>
설치 위치 네트워크인지 호스트인지로 나뉨

호스트 기반 침입탐지시스템(HIDS)
- 단일 호스트에 설치되어 해당 시스템의 감사 데이터를 사용해 침입을 탐지하는 시스템
- 시스템의 파일들에 대한 무결성을 점검한다.
- 네트워크 기반 IDS 에서 탐지하지 못하는 침입 탐지(버퍼 오버 플로우 등)가 가능
- 중요한 파일이 수정되었는지 또는 임의의 사용자가 보안 수준을 넘는 파일들로 접근하려 시도했는지를 감지
- 네트워크 환경에 구애받지 않는 장점을 가지고 있다.
- 공격의 성공, 실패 여부의 식별이 가능

네트워크 기반 침입탐지시스템(NIDS)
- 네트워크 세그먼트를 감시하는 전용 시스템
- 방화벽 외부 네트워크 세그먼트나 내부의 주요 네트워크 세그먼트에 설치
- 네트워크 기반의 IDS는 네트워크 패킷들을 검사하여 알려진 공격들이나 의심스러운 행동에 대하여 분석.
- HIDS와 달리 네트워크 세그먼트를 감시, 효과적인 침입탐지 환경을 갖출 수 있고
네트워크 서버들의 호환성과 상관없이 기존 서비스의 중단 및 영향 없이 시스템을 구축 가능
- 네트워크상의 흘러 다니는 모든 트래픽을 검사하므로 네트워크 트래픽 용량에 영향을 많이 받는 단점이 있다.
[해설작성자 : 한비로]

32. 지식기반 침입탐지이 아닌 것은?

① 통계적 분석(Statistical Analysis)
② 시그너처 분석(Signature Analysis)
③ 페트리넷(Petri-net)
④ 상태전이분석(State Transition Analysis)

<문제 해설>
지식기반 침입 탐지 : 알려진것과 일치하는 경우를 침입으로 간주
- 전문가 시스템
- 신경망
- 시그니처 분석
- 페트리넷
- 상태전이 분석
- 유전 알고리즘 등

행위기반 침입 탐지 : 패턴을 분석한 후 입력된 패턴과 비교하여 침입을 탐지
- 전문가 시스템
- 신경망
- 통계적 방법
- 컴퓨터 면역학
- 데이터 마이닝
- HMM(Hidden Markov Model)
- 기계학습
[해설작성자 : 한비로]

33. 무선랜 보안에 대한 설명으로 옳지 않은 것은?

① WEP 보안프로토콜은 RC4 암호 알고리즘을 기반으로 개발되었으나 암호 알고리즘의 구조적 취약점으로 인해 공격자에 의해 암호키가 쉽게 크래킹되는 문제를 가지고 있다.
② 소규모 네트워크에서는 PSK(PreShared Key) 방식의 사용자 인증이, 대규모 네트워크인 경우에는 별도의 인증 서버를 활용한 802.1x 방식의 사용자 인증이 많이 활용된다.
③ WPA/WPA2 방식의 보안프로토콜은 키 도출과 관련된 파 라미터 값들이 암호화되지 않은 상태로 전달되므로 공격자 는 해당 피라미터 값들을 스니핑한 후 사전공격(Dictionary attack)을 시도하여 암호키를 크래킹할 수 있다.
④ 현재 가장 많이 사용 중인 암호 프로토콜은 CCMP TKIP 이며 이 중 여러 개의 암호키를 사용하는 'TKIP역 보안성이 더욱 우수하며 사용이 권장되고 있다.

<문제 해설>
TKIP (Temporal Key Integrity Protocol)
- 2002년 12월경 미리 도입 확산시킨 암호화 방식
- 액세스 포인트에서 TKIP 를 허용하지 않을 계획이며 2012년까지 모든 Wi-Fi 장치에서 표준으로 혀용하지 않음
- WEP 는 2013년부터 액세스 포인트에서 표준이 금지되었고 1년 후에는 거의 쓸모없고 구식인 암호화 표준이 됨
- WPA2, 802.11 규격에서는, 비록 선택 사항으로 유지되고 있으나, 점차 배제됨
(WPA2 - TKIP를 허용하는 혼합 모드도 2014년으로 이동하여 WPA2-AES만 남음)
[해설작성자 : 무선랜 역사까지]

34. IPSec 보안 프로토콜에서 메시지 출처 인증, 메시지 무결성, 메시지 기밀성 서비스를 지원하는 프로토콜과 새로운 IP헤 더가 추가되는 동작모드가 잘 묶여진 것은?

① ESP 프로토콜, Transport 동작모드
② ESP 프로토콜, Tunnel 동작모드
③ AH 프로토콜, Transport 동작모드
④ AH 프로토콜, Tunnel 동작모드

<문제 해설>
★IPsec 동작 모드
Transport Mode(전송모드)
- IP Packet의 Payload만 캡슐화하고 IP Header는 그대로 유지
- 종단 노드(End node) <-> 종단 노드(End node) 구간의 IP Packet 보호를 위해 사용

Turnel Mode
- IP Packet 전체를 캡슐화하고, 전송구간(터널/보안 게이트웨이) 주소 정보를 담은 [New IP Header] 추가됨
- 터널/보안 게이트웨이 ↔ 터널/보안 게이트웨이 구간 또는 종단 노드 <-> 터널/보안 게이트웨이 구간의 IP Packet 보호를 위해 사용

★IPsec 세부 프로토콜
AH(Authentication Header) 프로토콜
- 메시지 인증 코드(MAC)를 이용하여 인증(무결성), 송신처 인증(Authentication) 제공

ESP(Encapsulating Security Payload) 프로토콜
- 메시지 인증 코드(MAC)와 암호화를 이용하여 인증(무결성), 송신처 인증(Authentication), 기밀성(Confidentiality) 제공
[해설작성자 : 한비로]

35. 다음 지문이 설명하고 있는 것은?

인터넷이나 다른 네트워크 메시지가 서버에 도착하였을 때, 전달되어야 할 특정 프로세스(응용프로그램)를 인식(구분)하기 위하여 필요하다.

① IP 주소 ② 포트번호
③ LAN 주소 ④ MAC 주소

<문제 해설>
포트(포트번호)/ 논리적인 접속장소
인터넷이나 기타 다른 네트워크의 메시지가 서버에 도착하였을 때, 전달 되어야할 특정 프로세스를 인식하기 위한 방법
데이터를 주고 받는 프로세스를 식별하기 위해 내부적으로 프로세스가 할당받는 고유한 값
[해설작성자 : 한비로]

36. NAC의 주요기능과 가장 거리가 먼 것은?

① 접근제어/인증 : 네트워크의 모든 IP기반 장치 접근제어
② PC 및 네트워크 장치 통제 : 백신 및 패치 관리
③ 해킹/Worm/유해 트래픽 탐지 및 차단 : 해킹행위 차단 및 완벽한 증거수집 능력
④ 컴플라이언스 : 내부직원 역할기반 접근제어

<문제 해설>
NAC 주요기능
접근제어/인증
- 내부직원 역할기반 접근제어
- 네트워크의 모든 IP 기반 장치 접근제어

PC 및 네트워크 장치 통제(무결성 체크)
- 백신 관리
- 패치 관리
- 자산 관리(비인가 시스템 자동 검출)

해킹/웜/유해 트래픽 탐지 및 차단(모니터링)
- 유해트래픽 탐지 및 차단
- 해킹 행위 차단
- 완벽한 증거수집 능력

컴플라이언스
- 사내 정보보호 관리체계 통제 적용
- 정기 / 비정기 감사 툴로 사용

>> 내부직원 역할기반 접근제어 => 접근제어/인증
문제 안좋음
[해설작성자 : 한비로]

37. Enterprise Security Management의 구성요소에 대한 설명으로 옳지 않은 것은?

① 에이전트 : 보안 장비에 탑재, 수집된 데이터를 매니저 서버에 전달하고 통제를 받음.
② 매니저 : 에이전트에서 받은 이벤트를 룰에 의해 분석 저장, Console Part에 그 내용을 인공 지능적으로 통보
③ 콘솔 : 매니저에게 받은 데이터의 시각적 전달, 상황 판단 기능
④ 보안 패치 : 다른 환경을 가진 컴퓨터를 대상으로 중앙에서 자동으로 통제 및 제어함으로써 각종 소프트웨어의 취 약점에 대한 보안 사고를 사전에 예방

<문제 해설>
ESM의 구성요소 : 에이전트, 매니저 , 콘솔
[해설작성자 : 운이없는야돈]

통합 보안관제 시스템(ESM)

구성 요소
Agent,Manager,console로 구성.

Agent
- 각종 보안 솔루션의 로그를 수집하는 역할.
- 로그를 수집하여 정규표현식으로 변환 후 manager에게 전달.

Manager
- 로그를 데이터베이스에 저장하고 분석.
- SSL을 이용해 Agent에게 console로 명령 하달.

Console
- 보안정보를 모니터링하여 침입 발생 시 명령을 manager에게 전달.
- 침입 알람을 발생하여 화면에 제공.
[해설작성자 : 맞나? 맞아라]

38. 다음 중 제시된 Well Known Port 번호에 해당하는 프로토콜을 순서대로 가장 적합하게 제시한 것은?

(가) 22번 포트 (나) 53번 포트 (다) 161번 포트

① (가) SSH, (나) Gopher, (다) NetBIOS
② (가) SSH, (나) DNS, (다) SNMP
③ (가) FTP, (나) Gopher, (다) SNMP
④ (가) FTP, (나) DNS, (다) NetBIOS

<문제 해설>
20 TCP FTP, File Transfer Protocol - 데이터 포트
21 TCP FTP, File Transfer Protocol - 제어 포트
22 TCP ssh scp, sftp같은 프로토콜 및 포트 포워딩
23 TCP 텔넷 프로토콜 (Telnet Protocol) - 암호화되지 않은 텍스트 통신
53 TCP UDP DNS, Domain Name System
69 UDP TFTP, Trivial File Transfer Protocol
80 TCP UDP HTTP
88 TCP 커베로스 - 인증 에이전트
123 UDP NTP - 시간 동기화
161 UDP SNMP - Agent 포트
162 UDP SNMP - Manager 포트
443 TCP HTTPS
[해설작성자 : 한비로]

39. 어떤 프로토콜에 대한 DoS 공격인가?

- "목적지 도달 불가(Destination Unreachable)' 메시지가 일부 방화벽에서 상당히 많은 리소스를 소비한다는 사실을 이용한다.
- 이 DOS 기술은 방화벽을 트래픽으로 뒤덮어버리는 것이 아니라, CPU를 high load 시키기 때문에 효율적이다.

① ICMP ② HTTP
③ TCP ④ SMTP

<문제 해설>
ICMP Flood
스머프 공격(Smurf attack)이라고도 부르는 이 공격은 공공 인터넷 상에서의 Flood DoS 공격의 한 변종
- 취약한 네트워크의 호스트들이 공격대상에 응답 합
- 공격대상은 한꺼번에 전달되는 비정상 응답을 처리해야 하므로 부하가 발생 함
[해설작성자 : 맞나]

40. DoS 공격 중 Land 공격이 조작하는 IP 프로토콜의 필드에 해당하는 것은 무엇인가?

① 출발지 주소 ② 목적지 주소
③ Time-To-Live 값 ④ 헤더의 길이

<문제 해설>
LAND ATTACK
- IP스푸핑을 이용한 SYN 공격
- 출발지주소를 변경한(spoofed) TCP SYN 패킷을 보냅니다. (출발지와 도착지의 IP를 피해자의 IP로 동일하게)
- 패킷을 받은 시스템은 TCP SYN-ACK을 자신에게 보내게 되고 유휴시간제한(Idle timeout)까지 빈 연결 만들게 됩니다..
- 이를 반복하면 시스템에는 빈 연결이 계속해서 쌓여 시스템 버퍼가 범람하게 되고, 서비스거부(DoS) 상태가 됨
[해설작성자 : 한비로]

3과목 : 어플리케이션 보안

41. 포맷스트링 취약점의 직접적인 위험이 아닌 것은?

① 프로그램의 복제
② 프로그램의 파괴
③ 프로세스 메모리 보기
④ 임의의 메모리 덮어쓰기

<문제 해설>
포맷스트링 공격(Format String Attack)
포맷스트링과 이것을 사용하는 printf() 등의 함수의 취약점을 이용하여 코드의 주소를 읽어 값을 획득하는 해킹 공격

포맷스트링 취약점 공격
- 프로그램 다운 가능
- 프로세스 메모리 스택 확인
- 메모리의 임의의 위치 확인
[해설작성자 : 한비로]

42. 웹 공격 기법은?

게시판의 글에 원본과 함께 악성코드를 삽입하여 글을 읽을 경우 악성코드가 실행되도록 하여 클라이언트의 정보를 유출하는 클라이언트에 대한 공격 기법

① SQL Injection 공격
② 부적절한 파라미터 조작 공격
③ 버퍼 오버플로우 공격
④ XSS(Cross Site Scripting) 공격

<문제 해설>
크로스 사이트 스크립팅(Cross Site Scripting, XSS)
웹사이트에 악성 스크립트를 주입하는 행위
웹사이트를 변조하거나, 악의적 콘텐츠를 삽입하거나, 피싱 공격을 진행하는 것
[해설작성자 : 맞나?]

43. 아래 그림은 웹 해킹과 관련된 로그이다. 이 그림을 보고 짐작할 수 있는 웹 공격 기법은?

```
10.10.10.1 - - [10/an/2017.00:1803 10900] E
/home/login/login.php?
userid=%27%2008%201%201%20%2D
HTTP/"1.1" 200 970
"http://10.10.10.20/home/login/ogin_form.php"
"Mezia-50 (Windows NT 6.3, WOW64;
Tricent/7.0; v.11.0)
like Cecko)
```

① SQL Injection
② Cross Site Request Forgery
③ Distribute Denial of Service
④ Cross Site Script

<문제 해설>
웹 서버에 보기와 로그를 발견하였다면
user 값의 페이로드 값을 id='user' and pw='1' or 1=1 라는뜻의 퍼센트 인코딩으로 변환된 값으로 시도하는것입니다.
즉, 특정 웹페이지 접근 시 조작된 매개변수를 전달하고 있음으로 공격으로 판단.

id='user' and pw='1' or 1=1 형태의 SQL 조건문(Where절) 조작을 위한 매개변수입니다.

웹 브라우저에서공백이나 특수문자를 전달하기 위한
URLEncoding을 하고 있으므로
인코딩된 ‘, = , 공백등을 주의깊게 살펴야 합니다.
[해설작성자 : 한비로]

아래와 같은 오류 신고가 있었습니다.
여러분들의 많은 의견 부탁 드립니다.
추후 여러분들의 의견을 반영하여 정답을 수정하도록 하겠습니다.
참고로 정답 변경은 오류 신고 5회 이상일 경우 수정합니다.

[오류 신고 내용]
문제에 오류가 있었을것같습니다.
%27%2008%201%201%20%2D 값의 해석은 아래와 같이 해석됩니다.
' 08 1 1 -
본래 말하고자 하였던것은 다른 sql injection 문장이였을것으로 판단됩니다.
==========
[해설작성자 : 한비로]

44. FTP 전송모드에 대한 설명으로 옳은 것은?

① 디폴트는 active 모드이며, passive 모드로의 변경은 FTP 서버가 결정한다.
② 디폴트는 active 모드이며, passive 모드로의 변경은 FTP 클라이언트가 결정한다.
③ 디폴트는 passive 모드이며, active 모드로의 변경은 FTP 서버가 결정한다.
④ 디폴트는 passive 모드이며, active 모드로의 변경은 FTP 클라이언트가 결정한다.

<문제 해설>
FTP의 기본 디폴트는 active 모드이다..passive 모드로의 변경은 서버가 아닌 클라이언트가 결정한다.
기본 모드인 active모드로 FTP 이용을 제한하는 경우도 있는데, passive모드로의 변경을 하면 해결된다.
[해설작성자 : Melbourne]

45. 어떤 종류의 취약점에 대응하기 위한 대책인가?

PHP의 경우 php.ini 파일에서 allow_url_fopen 옵션을 Off값으로 설정

① 부적절한 파라미터 조작
② 원격지 파일의 명령 실행
③ SQL Injection
④ 쿠키 세션 위조

<문제 해설>
php.ini 에서 allow_url_fopen 을 On으로 설정 시
공격자가 url을 연결하여 파일을 작성하거나 읽어 올 수있음,
악성파일 주입 및 실행이 가능하므로 설정값을 off로 설정하는 것이 좋음
[해설작성자 : 한비로]

46. 다음 지문의 설명은 FTP의 어떤 공격 유형에 속하는가?

- 익명 FTP 서버를 이용하고 그 FTP 서버를 경유하여 호스트를 스캔한다. - FTP 포트 명령어를 이용한다. - FTP 서버를 통해 임의의 네트워크 접속을 릴레이하여 수행한다. - 네트워크 포트를 스캐닝하는데 사용한다. - FTP 프로토콜의 취약점을 이용한 공격이다.

① Bounce 공격 ② Anonymous FTP 공격
③ TFTP 공격 ④ 스니핑 공격

<문제 해설>
Anonymous FTP: 익명 FTP 서버를 이용해 공격자가 자신을 숨기고 PORT 명령을 조작하여 공격대상의 네트워크 및 포트스캔, Fake Mail 전송, 데이터 전송이 가능이 가능하다.
[해설작성자 : Melbourne]

Anonymous FTP: 익명 사용자가 서버에 쓰기 권한이 있으면 악성코드 업로드 가능
[해설작성자 : Melbourne]

47. 다음에서 설명하는 전자우편의 보안요소로 옳은 것은?

"중간에서 지나가는 메일을 잡아 놨다가 다시 보내는 공격 방 법을 방지해 주는 기능"

① 메시지 무결성(Message Integrity)
② 메시지 재생 방지(Message replay prevention)
③ 사용자 인증(User Authentication)
④ 송신자 부인 방지(Nonrepudiation of Origin)

<문제 해설>
- 전자 우편의 보안 기능

메시지 기밀성(Confidentiality)
해당자가 아닌 사용자들은 내용을 볼 수 없게 하는 기능

메시지 인증(Message Integrity)
전송 도중에 내용이 불법적으로 변경되었는가를 확인해 주는 기능

사용자 인증(User Authentication)
메일을 실제로 보낸 사람이 송신자라고 주장한 사람과 일치하는가를 확인해 주는 기능

송신 부인 방지(Non-repudiation of Origin)
송신자가 메일을 송신하고서도 송신하지 않았다고 주장하는 경우 이를 확인해 주는 기능

수신 부인 방지(Non-deniability of Receipt)
메일을 수신하고도 나중에 받지 않았다고 주장하지 못하게 해주는 기능

메시지 재연 방지(Message Replay Prevention)
중간에서 지나가는 메일을 정지했다가 다시 보내는 공격 방법을 방지해 주는 기능
: ***재생 공격
데이터를 가로채서 재전송 하는 공격자 또는 발신자에 의해 수행
> 메세지 재생방지의 대응을 위해 세션키 등의 암호화방법을 사용
[해설작성자 : 한비로]

48. 다음 중 스팸 필터 솔루션에 대한 설명 중 가장 부적절한 것은?

① 메일 서버 앞단에 위치하며 프락시 메일 서버로 동작한다.
② SMTP 프로토콜을 이용한 DoS 공격이나 폭탄 메일, 스팸메일을 차단한다.
③ 메일헤더 및 제목 필터링은 제공하지만 본문에 대한 필터링은 제공하지 못한다.
④ 첨부파일 필터링 기능을 이용하여 특정 확장자를 가진 파일만 전송되도록 설정할 수 있다.

<문제 해설>
스팸으로 판단 가능 요소 :
- 스팸전송자로 알려진 특정 이메일주소,스팸발송 메일서버 IP
- 스팸전송 사이트로 알려진 특정 웹사이트 URL,
- 스팸메일에서 많이 사용되는 제목 단어,대량 전송 여부
- 메시지 제목 및 본문 키워드 검색에 의한 차단
- 메일헤더에 의한 차단기능
- 메일 헤더의 Data의 유효성,도메인 위조 차단
- 첨부파일 및 스크립트 형태의 바이러스 검색,치료 및 제거
- 관리자별/개인별 스팸 룰에 의한 차단
[해설작성자 : 한비로]

49. 다음 중 PGP(pretty good privacy)의 기능이 아닌 것은?

① 전자서명 ② 기밀성
③ 단편화와 재조립 ④ 송수신 부인방지

<문제 해설>
PGP(Pretty Good Privacy):
전자우편 암.복호화(기밀성),메시지 인증(무결성),사용자 인증, 송신처 부인방지만 지원.
pam에 비해 보안성은 못하지만, 프로그램이 공개 되어 현재 가장 많이 사용.
이메일 보안 기능 중 수신 부인 방지, 메시지 부인 방지는 지원하지 않음.
[해설작성자 : 해설을 보세요]

50. 다음 중 E-mail 전송 시 보안성을 제공하기 위한 보안 전자우편 시스템이 아닌 것은?

① PGP(Pretty Good Privacy)
② S/MIME(Secure Multipurpose Internet Mail Extension)
③ PEM(Privacy Enhanced Mail)
④ SSL(Secure Socket Layer)

<문제 해설>
SSL은 암호화 기반 인터넷 보안 프로토콜이다..인터넷 통신의 개인정보 보호, 인증, 데이터 무결성을 보장하기 위한 표준 기술
[해설작성자 : Melbourne]

51. 다음 중 FTP 보안대책과 가장 거리가 먼 것은?

① anonymous 사용자의 루트 디렉터리, bin, etc, pub 디렉터리의 소유자와 permission 관리
② root 계정의 ftp 접속 제한
③ 최신 ftp 서버 프로그램 사용 및 주기적인 패치
④ ftp 접근제어 설정 파일인 ftpusers 파일의 소유자를 root로 하고, 접근 허용할 계정을 등록

<문제 해설>
ftpusers에는 접근 거부할 계정을 넣습니다.
[해설작성자 : 보안기사괜히접수했다]

52. 다음의 지문에서 설명하고 있는 기술들은 전자상거래의 안전성을 지원할 목적으로 이용되는 보안 프로토콜이다. 빈칸 에 들어가야 할 적합한 단어는?

> 전자상거래의 안전성을 지원할 목적으로 IPSec(Internet Protoooo Security), SSL (Secure Socket Layer), OTP(One Time Password) 등이 사용된다. 이 중 IPSec은 (㉠) 계층에서 SSL은 (㉡) 계 층에서, OTP는 (㉢) 계층에서 각각 동작된다.

① ㉠네트워크, ㉡ 전송, ㉢ 응용
② ㉠네트워크, ㉡ 응용, ㉢ 전송
③ ㉠ 응용, ㉡ 네트워크, ㉢ 전송
④ ㉠ 응용, ㉡ 응용, ㉢ 전송

<문제 해설>
네트워크 계층의 암호화 프로토콜 - IPsec
전송계층의 암호화 프로토콜 - SSL
응용계층의 암호화 프로토콜 - OTP
[해설작성자 : 한비로]

53. 다음 지문이 설명한는 기술의 명칭은?

> 공공 거래 장부이며 가상 화폐로 거래할 때 발생할 수 있는 해킹을 막는 기술이다.
> - 분산 데이터베이스의 한 형태로, 지속적으로 성장하는 데이터 기록 리스트로서 분산 노드의 운영자에 의한 임의 조작이 불가능하도록 고안되었다.

① 블록체인 ② 라이트닝 네트워크
③ ECDSA ④ 인공지능

<문제 해설>
블록체인
P2P 방식을 기반으로 하여 모든 거래 내역이 기록되어 있고 소규모 데이터들이 체인 형태로 무수히 연결되어 형성된 '블록'이라는 분산 데이터 저장 환경에 관리 대상 데이터를 저장함으로써 누구도 임의로 수정할 수 없고 누구나 변경의 결과를 열람할 수 있게끔 만드는 기술
[해설작성자 : 맞나?아닌가?]

54. 다음 지문이 설명하고 있는것은?

> 이 솔루션은 인증을 통해 자산 및 사용자를 식별하고, 네트워크 접근권한 등을 부여하며 사용자 접속권한을 제어한다. 인가 받지 않은 단말에 대해 내부 네트워크 접근 통제가 가능하다.

① IPS ② Firewall
③ NAC ④ ESM

<문제 해설>
NAC

접근 권한등의 보안정책을 준수했는지 여부를 검사하여 네트워크 접속을 통제가능한 기술
엔드포인트(단말기)등의 보안접근을 통제가능
[해설작성자 : 한비로]

55. DNSSEC에 대한 설명 중 가장 적절하지 않은 것은?

① DNS 메시지에 대한 기밀성을 제공한다.
② 서비스 거부 공격에 대한 방지책은 없다.
③ DNS 데이터 위·변조 공격에 대응할 수 있다.
④ 메시지 송신자 인증과 전자서명을 제공한다.

<문제 해설>
DNS(domain name system) 가 가지는 보안 취약점을 극복하기 위한 확장 표준 프로토콜을 말하는 것인데 이를 축약하여 DNSSEC이라 칭한다.
○ 무결성 검증 수행 (전자서명 복호화 값과 원본 데이터 해쉬값 일치 여부 확인)
○ 해커가 웹 주소를 다른 주소로 변조 했더라도, 사용자 DNS가 검증 과정에서 이를 발견하여 차단함으로 인터넷 이용자의 피해를 방지한다.
[해설작성자 : 해설을 보세요]

56. SSL 프로토콜에 대한 설명이다. 적절치 못한 것은?

① SSL을 사용하기 위해서는 URL에 "http:// 대신에 "https://"을 사용한다.
② SSL 프로토콜은 Default로 TCP 443 Port를 사용한다.
③ SSL 프로토콜은 암호화 통신을 하기 때문에 침입탐지 방지시스템(IDS/ITS) 등의 보안장비에서 공격 페이로드의 탐지가 쉽다.
④ SSL은 Record Layer와 HandShake Layer로 구분한다.

<문제 해설>
IDS/IPS는 패킷 및 방화벽 단의 침입방지 시스템이므로 ssl 패킷단위 탐지와 SSL 프로토콜의 탐지가 어렵다.(가능하더라도 성능저하가...)
[해설작성자 : 한비로]

57. 다음 중 OWASP TOP 10 2017에서 새로 선정된 보안취약점은?

① 인젝션
② 인증 취약점
③ 크로스사이트 스크립트
④ XXE

<문제 해설>
Open Web Application Security Project

2013
1 인젝션
2 취약한 인증과 세션 관리
3 크로스 사이트 스크립팅
4 안전하지 않은 직접 객체 참조
5 잘못된 보안 구성
6 민감한 데이터 노출
7 기능 수준의 접근 통제 누락
8 크로스 사이트 요청변조(CSRF) ★ 삭제
9 알려진 취약점이 있는 구성요소 사용
10 검증되지 않은 리다이렉트 및 포워드 ★ 삭제

2017
1 인젝션
2 취약한 인증
3 민감한 데이터 노출
4 XML 외부 개체(XXE) ★ 신규
5 취약한 접근 통제
6 잘못된 보안 구성
7 크로스 사이트 스크립팅(XSS)
8 안전하지 않은 역직렬화 ★ 신규
9 알려진 취약점이 있는 구성요소 사용
10 불충분한 로깅 및 모니터링 ★ 신규

2021 (최신)
1 취약한 접근 통제
2 암호화 오류(민감한 데이터 노출에서 명칭변경)
3 인젝션
4 불안전한 설계 ★ 신규
5 잘못된 보안 구성
6 취약하고 오래된 요소(알려진 취약점이 있는 구성요소 명칭변경)
7 식별 및 인증 오류(취약한 인증의 넓은범위)
8 소프트웨어 및 데이터 무결성 오류 ★ 신규
9 보안 로깅 및 모니터링 오류 (불충분한 로깅 및 모니터링 명칭변경)
10 SSRF, 서버측 요청 위조 ★ 신규
[해설작성자 : 한비로]

58. BYOD 보안솔루션과 가장 거리가 먼 것은?

① NAC ② MDM
③ MAM ④ ESM

<문제 해설>
BYOD(Bring Your Own Device)란?
직원들의 개인용 스마트폰, 태블릿PC, 노트북 등 정보기술(IT) 기기를 직장에 가져와 업무에 활용하는 것..

BYOD 단점
직원들의 스마트폰과 개인 태블릿, 노트북을 업무에 사용하므로 기업 데이터 유출이 큰 단점

보안 대책
MDM(Mobile Device Management): 휴대폰 정보의 유출을 막는 솔루션
MDP(Mobile Data Protection): 모바일 데이터 보호 솔루션
NAC(Network Access Control): 네트워크에 액세스하는 디바이스에 정책을 적용하는 보안 솔루션
[해설작성자 : 해설을 보세요]

MAM - 기업용 애플리케이션과 관련 데이터만을 통제

[해설작성자 : 보안기사괜히접수했다]

59. 다음 보기가 설명하고 있는 공격 방식은?

> 해커가 특정 기업, 기관 등의 HW 및 SW 개발, 공급과정 등 에 침투하여 제품의 악의적 변조 또는 제품 내부에 악성코드 등을 숨기는 행위로 최근에 국내 SW 개발사를 대상으로 SW가 제작되는 단계에서 설치파일 변조 침해사고가 여러 차례 확인된 바 있다. 이러한 사고 예방을 위해서는 개발환경은 외부 인터넷을 차단하여 운영하여야 한다.

① developer chain attack
② supply chain attack
③ stuxnet attack
④ scada attck

<문제 해설>
공급사슬 공격(supply chain attack)
특정 기관의 컴퓨팅 체계 개발 작업에 끼어들어 악성 코드나 해킹 도구를 미리 숨겨 둔 뒤 해를 끼치는 행위.
정상적이고 일상적인 컴퓨팅 체계 개발 작업에 숨어들기 때문에 피해 규모와 범위를 가늠하기 어렵다
[해설작성자 : 해설을 보세요]

60. 다음의 설명 및 조치 내용에 해당하는 취약점은?

> 공격자가 사용자의 cookie 값이나 session 정보를 의 도한 사이트로 보내거나 특정한 동작을 유발하는 스크립트를 글에 삽입하여 사용자가 게시물 등을 클릭할 경우 공격자가 원하는 동작(계좌이체, 물건주문 등)이 실행되게 하는 취약점 (단, 공격 대상자가 사이트에 로그인해 있거나 유효한 cookie, session 정보를 가지고 있어야 공격이 성공할 수 있음)

① SQL injection(sql 명령어 삽입)
② CSRF(크로스사이트 요청변조)
③ RFI(원격 파일 포함)
④ Directory Listing(디렉터리 목록 노출)

<문제 해설>
CSRF(크로스 사이트 요청 변조)
일반 사용자가 의지와는 무관하게 공격자가 의도한 행위를 특정 웹사이트에 요청하게 만드는 공격
[해설작성자 : 한비로]

4과목 : 정보 보안 일반

61. MAC 정책의 특징에 대한 설명으로 가장 부적절한 것은?

① 객체의 소유주가 주체와 객체간의 접근 통제 관계를 정의
② 보안관리자 주도 하에 중앙 집중적 관리가 가능
③ 접근 규칙수가 적어 통제가 용이
④ 사용자와 데이터는 보안 취급허가를 부여 받아 적용

<문제 해설>
강제적 접근통제 (MAC : Mandatory Access Control)
1. 규칙이 단순해 관리가 용이
2. 개인, 데이터별로 명확한 보안등급을 가진다
3. 접근 승인은 보안레벨과 카테고리로 구성된 보안레이블에 의해 제한됨
4. 접근 정책은 시스템에 의해서 강제적으로 정의됨
5. 오렌지북 B 레벨의 요구사항으로 DAC보다 안전
6. 매우 엄격하여 군대같은 민감한 정보의 기밀성을 보장하는데 사용됨
7. 모든 접근에 대해 보안등급을 정의하고 확인해야 하기 때문에 개발, 구현이 어려움

임의적 접근통제 (DAC : Discretionary Access Control)
1. 접근 권한을 객체의 소유자가 임의로 지정하는 자율적 정책
2. 접근통제 목록(ACL) 등을 사용
3. 허가된 주체에 의하여 변경 가능한 하나의 주체와 객체간의 관계를 정의
4. 오렌지북 C 레벨의 요구사항이다
5. 상업적 용도로 사용된다
6. 신분 도용시 통제 방법이 없다
[해설작성자 : 맞나?아닌가?]

62. 다음의 지문이 설명하고 있는 접근 통제 보안모델은?

> 이 모델은 데이터 무결성에 초점을 둔 상업용 접근 통제 보안 모델이다. 이 모델에서는 비인가자들의 데이터 변형에 대한 방 지만 취급하며, 주체는 보다 낮은 무결성의 정보를 읽을 수 없 다.(no read down policy)주체는 또한 자신보다 높은 무결성 수준의 객체를 수정할 수 없다.(no wile up policy) 이 모델은 상태 머신(state mechine) 모델에 기반을 두고 있다.

① Bell-LaPadula Model
② Biba Model
③ Clark-Wilson Model
④ Lattice Model

<문제 해설>
벨-라파듈라 모델 >> 주체는 자신보다 높은 보안 수준의 객체를 읽을 수 없다.
- No Write Down
- 군사용 보안 정책
- 오직 기밀성을 강조하는 MAC(Mandatory Access Control)모델이다.
- 허가된 비밀 정보에 허가되지 않는 방식의 접근을 금지한다.
- 정보의 불법적인 유출을 막기위해 개발된 최초의 수학적 모델이다

비바 무결성 모델 >> 주체는 자신보다 높은 무결성 수준을 갖는 주체에게 서비스를 요청할 수 없다.
- No Read Down, No Write Up
- 벨-라파듈라의 단점을 보완한 상업용 무결성 모델
- 정보는 고의적인, 비인가된, 우연한 변경으로부터 보호되어야 한다는 무결성의 3가지 원칙 중 비인가된 변경만 취급한다.

클락-윌슨 무결성 모델 >> 데이터를 하나의 일치 상태에서 다

른 일치 상태로 변경해야 한다.(정확한 트랜잭션)
- 주체/프로그램/객체의 세 부분 관계를 사용한 무결성 모델이다.
- 무결성을 중심으로 군사용보단 상업용을 목적으로 설계되었다..(상업용 연산에 가깝게 설계)
- 무결성의 3가지 목적(비인가자의 위변조 방지, 직무분리라, 정확한 트랜잭션)을 구현한다.
[해설작성자 : 한비로]

63. Kerberos 프로토콜을 개발함에 있어 요구사항으로 고려 지 않은 특성은?

① 보안성 ② 재사용성
③ 투명성 ④ 확장성

<문제 해설>
커버로스 특징
- 기업 접근통제를 위해 확장성, 투명성, 안정성, 보안을 필요로 한다.
- 사용자에게 동일한 계정정보로 여러 가지 서비스 제공
- 유효기간 내에 티켓을 이용해 동일한 서버에서 여러 가지 응용서비스 제공 받을수 있다.

티켓을 재사용하기에 조금 아리까리한 문제
[해설작성자 : 맞나?아닌가?]

64. 다음 중 평문과 같은 길이의 키를 생성하여 평문과 키를 비트단위로 XOR하여 암호문을 얻는 방법에 해당하는 것은?

① 스트림 암호 ② 대칭키 암호
③ 공개키 암호 ④ 블록 암호

<문제 해설>
스트림 암호
평문과 같은 길이의 키를 생성하여 평문과 키를 비트단위로 XOR 연산으로 평문과 키 스트림과의 결합에 의해서 생성

대칭 키 암호
송수신자가 암호화나 복호화를 할 때 같은 키를 쓰는 알고리즘

공개키 암호
암호화에는 공개 키가 사용되고 복호화에는 개인 키가 사용되는 암호 방식

블록 암호
암호문을 만들기 위해 암호 키와 알고리즘이 블럭 단위의 평문에 적용되는 대칭 암호화 방식
[해설작성자 : 한비로]

65. 다음 각 지문은 공개키 암호에서 어떠한 보안기능을 제공하기 위한 것인가?

(㉠) : 수신자의 공개키로 암호화하여 송신한다.
(㉡) : 발신자의 개인키로 암호화하여 송신한다.

① ㉠ 비밀성, ㉡ 부인방지
② ㉠ 무결성, ㉡ 비밀성
③ ㉠ 부인방지, ㉡ 무결성
④ ㉠ 가용성, ㉡ 비밀성

<문제 해설>
(㉠) : 수신자의 공개키로 암호화하여 송신한다.
====> 수신자의 개인키로만 풀 수 있다..수신자만 풀 수 있어서 암호문이 탈취되어도 못본다..(비밀성 보장, 제 생각엔 기밀성이라고 해야할듯하지만 뭐...)

(㉡) : 발신자의 개인키로 암호화하여 송신한다.
====> 발신자의 공개키로 풀면 정상적으로 보인다..즉 발신자가 보냈다는게 증명됨.(부인 방지, 안보냈다고 발뺌 못함)
[해설작성자 : 보안기사괜히접수했다]

66. 다음은 CRL 개체 확장자를 구성하는 필드에 대한 설명이다. 잘못된 설명은?

① Reason Code : 인증서가 갱신된 이유를 나타내기 위해 사용되는 코드
② Hold Instruction Code : 인증서의 일시적인 유보를 지원하기 위해 사용되는 코드
③ Certificate Issuer : 인증서 발행자의 이름
④ Invalidity Date : 개인키 손상이 발생하는 등의 이유로 인증서가 유효하지 않게 된 날짜와 시간에 대한 값

<문제 해설>
Reason Code: 폐지의 원인을 정의 하기 위한 코드
[해설작성자 : 보안기사괜히접수했다]

67. 다음은 각 암호 알고리즘이 개발된 배경을 설명한 것이다. 틀린 것은?

① 스트림 암호는 One Time Pad를 실용적으로 구현할 목적으로 개발되었다.
② 블록 암호는 암호문의 위·변조를 막기 위해서 개발되었다.
③ 공개키 암호는 키 관리 문제를 극복하기 위해 개발되었다.
④ 해시 함수는 디지털 서명을 효과적으로 수행하기 위해 개발되었다.

<문제 해설>
해시함수의특성
임의의 길이를 갖는 메시지를 입력 받아 고정된 길이의 해시 값을 출력하는 함수
암호 알고리즘에는 키가 사용되지만, 해시 함수는 키를 사용하지 않으므로 같은 입력에 대해서는 항상 같은 출력이 나옴
이러한 해시 함수를 사용하는 목적은 메시지의 오류나 변조를 탐지할 수 있는 무결성을 제공하기 위해 사용
○ 역상 저항성: 임의의 출력값 y에 대해 y=h(x)를 만족하는 입력값 x를 찾는 것이 계산적으로 불가능
○ 두번째 역상 저항성: 임의의 출력값 x에 대해 h(x)=h(x'), x!=x'를 만족하는 다른 입력 값 x'를 찾는 것이 불가능
○ 충돌 저항성: h(x)=h(x')를 만족하는 임의의 두 입력 값 x, x'를 찾는 것이 계산적으로 불가능
○ 강일 방향성(Strong Onwayness): 서명문 M과 그의 해시값 H=h(M)이 있을 때 h(M')=H 가 되는 서명문 M!=M'

를 찾는 것이 불가능해야 함.
○ 약일 방향성(Weak Onewayness): h(M)=H 에서 서명문 M 값을 찾는 것이 불가능해야 함.
○ 충돌 회피성(Collision freeness): h(M)=h(M')의 서명문 쌍(M, M') (M!=M') 찾는 것이 불가능 해야 함.
[해설작성자 : 해설을 보세요]

68. 대칭키 암호화 알고리즘으로 묶여진 것은?

① DES, AES, MAC ② RC5, AES, OFB
③ SEED, DES, IDEA ④ Rabin, ECDSA, ARIA

<문제 해설>
1. 대칭키 암호
- 하나의 비밀키를 클라이언트와 서버가 모두 같이 사용
- 속도가 매우 빠름
- 암호 알고리즘 방식 : DES, 3-DES, AES, SEED, ARIA, IDEA, MASK
2. 공개키 암호
- 공개키와 비밀키 두 개가 각각 존재
- 암호화와 복호화에 사용하는 키가 서로 다름
- 암호 알고리즘 방식 : RSA, DSA, Elgamal, ECC 등
[해설작성자 : 한비로]

69. 다음 중 대칭키 배송 문제를 해결할 수 있는 방법에 해당하지 않는 것은?

① 키 배포 센터에 의한 해결
② Diffie-Hellman 키 교환 방법에 의한 해결
③ 전자서명에 의한 해결
④ 공개키 암호에 의한 해결

<문제 해설>
키 배송 문제를 해결하기 위한 방법
- 키의 사전 공유에 의한 해결
- 키 배포 센터 (케베로스)
- Diffie-Hellman 키 교환
- 공개 키 암호에 의한 해결
[해설작성자 : 한비로]

70. 해시함수의 요구사항과 가장 거리가 먼 것은?

① 계산용이성 ② 역방향성
③ 약한 충돌회피성 ④ 강한 충돌회피성

<문제 해설>
해시함수 보안요구 사항

계산용이성
쉽고 빠르게 계산이 가능해야 함

일방향성(단방향성)
- 해시값으로부터 해시되기 전의 원본데이터를 복구하거나 계산할 수 없다는 특성
(결과값으로는 입력 값을 알 수가 없는 또는 알기가 어려운 성질)

충돌회피성
- 동일한 해시값을 갖는 서로 다른 원본데이터를 찾을 수 없어야 하는 특성

>>>[참고] 해시 값이 동일하면서 다른 메시지가 존재하는 것을 충돌(collision)이라고 함
무결성을 확인하기 위해서는 충돌이 존재해서는 안 된다

약한충돌내성 : 주어진 입력값 x에 대해 h(x)=h(x'), x≠x'을 만족하는 다른 입력값 x'을 찾는 것이 계산적으로 불가능하다.
> 어느 메시지의 해시 값이 주어졌을 때 그 해시 값과 동일한 메시지를 발견해내는 것이 매우 곤란한 성질
강한충돌내성 : h(x)=h(x')을 만족하는 임의의 두 입력값 x, x'을 찾는 것이 계산적으로 불가능하다.
> 해시 값이 일치할 것 같은 서로 다른 2개의 메시지를 발견해내는 것이 매우 곤란한 성질

예시) 패스워드값은 일방향 해시값으로 처리되어야하며, 해당 값으로 원래의 패스워스를 알아낼 수 없어야함,
[해설작성자 : 한비로 두비로 세비로]

71. 다음 중 생체 인식의 요구사항과 가장 거리가 먼 것은?

① 획득성 ② 영구성
③ 구별성 ④ 유연성

<문제 해설>
획득성(Collectable) : 센서에 의한 획득과 정량화에 용이한 특성
영구성(Permanent) : 변하지 않고 변경이 불가한 특성
구별성(Unique) : 각 개인을 구별할 수 있는 고유한 특성

보편성(Universal) : 누구나 보편적으로 갖고 있는 특성
성능(Performance) : 개인 확인 및 인식성이 우수해야 함
수용성(Acceptance) : 거부감이 없어야 함
[해설작성자 : 한비로]

72. 능동적 공격에 해당되지 않는 것은?

① 메시지 변조 ② 전송되는 파일을 도청
③ 삽입공격 ④ 삭제공격

<문제 해설>
능동적 공격 : 시스템 자원을 변경하거나 작동에 영향을 끼침
수동적 공격 : 시스템에서 정보를 읽거나 사용하려고 시도하지만 시스템 자원에는 영향을 미치지 않음.
[해설작성자 : 한비로]

73. 다음의 공개키 암호에 대한 내용 중 잘못된 것은?

① 하나의 알고리즘으로 암호와 복호를 위한 키 쌍을 이용해 암호화와 복호화를 수행한다.
② 송신자와 수신자는 대응되는 키 쌍을 모두 알고 있어야 한다.
③ 두 개의 키 중 하나는 비밀로 유지되어야 한다.
④ 암호화 알고리즘, 하나의 키와 암호문에 대한 지식이 있어도 다른 하나의 키를 결정하지 못해야 한다.

<문제 해설>

공개키 암호에서 송신자는 암호화할 개인키를 알고있어야하고, 수신자는 복호화할 송신자의 공개키를 알고있어야한다.
[해설작성자 : Melbourne]

74. 블록암호에 대한 공격 방식과 가장 거리가 먼 것은?

① 선형공격
② 차분공격
③ 고정점 연쇄공격
④ 전수공격

<문제 해설>
블록암호에 대한 공격

차분분석
- 평문의 일부를 변경하여 암호문의 변화 형태를 조사하여 해독하는 방법

선형분석
- 평문과 암호문 비트 몇개를 XOR해서 0이 되는 확률을 조사하는 방법
- 선택평문공격(CPA) 할수 있음
(평문 공격법으로 알고리즘 내부의 비선형 구조를 선형화)

전수공격법
- 모든 경우의 수로 조사하는 방법

통계적분석
- 암호문에 대한 평문의 각 단어별 빈도 및 모든 통계 자료를 활용하여 조사하는 방법

수학적분석
- 통계적 방법을 포함하며 수학적 이론을 이용하여 해독(복호화)하는 방법
[해설작성자 : 한비로 두비로 세비로]

75. 인수 분해의 어려움을 기초로 한 공개키 암호화 알고리즘은?

① AES ② RSA
③ ECC ④ DH

<문제 해설>
소인수 분해의 어려움을 이용한 암호 알고리즘은 RSA이다.
[해설작성자 : Melbourne]

76. 블록 암호는 기밀성이 요구되는 정보를 정해진 블록 단위로 암호화 하는 대칭키 암호 시스템으로 알고리즘 구조는 파이스텔(Feistel) 구조와 SPN 구조가 있다. 다음 중 파이스텔 구 조 블록암호가 아닌 것은?

① DES ② AES
③ SEED ④ RC5

<문제 해설>
AES는 파이스텔이 아닌 SPN(레인달) 구조이다.
[해설작성자 : Melbourne]

77. 다음 인증 기술 중에서 종류가 다른 한 가지는?

① 개체 인증 ② 사용자 인증
③ 신원 인증 ④ 메시지 인증

<문제 해설>
1) 사용자 인증
- 사용자가 자신이 진정한 사용자라는 것을 상대방에게 증명할 수 있도록 하는 기능
- 제3자가 위장을 통해 사용자 행세를 하는 것이 불가능해야 한다
- 사용자 인증은 신원확인(Identification)이라고도 하는데, 서버에 로그인하는 경우 등 사용자의 신분을 확인 후 정보 서비스를 이용할 수 있는 권한을 부여하기 위해 사용된다
- 사용자 인증을 통과하면 원격접속자가 해당 사용자로서의 모든 권한을 수행할 수 있기 때문에 엄격한 인증절차를 거치도록 요구해야 한다
- 사용자 인증 => 개체인증 또는 신원인증과 같은 개념이다

2) 메시지 인증
- 메시지 인증이란 전송되는 메시지의 내용이 변경되지 않고 본래 정보를 가지고 있다는 것을 확인하는 것을 말함
- 전송되는 메시지가 변경되지 않았다는 사실과 누가 보낸다는 사실을 함께 증명하는 것은 전자서명을 통해 이룰 수 있다
[해설작성자 : 한비로]

78. 이중서명의 특징에 대한 설명으로 옳지 않은 것은?

① 분쟁에 대한 대비를 위해 두 메시지 간의 연관성이 구현되어야 함
② 구매자의 자세한 주문정보와 지불정보를 판매자와 금융기관에 필요 이상으로 전달하지 않아야 함
③ 이중 서명은 SSL에서 도입된 기술로 고객의 카드 정보를 상인에게 전달하면 상인은 그 요청에 유효성을 확인하게 됨
④ 구매자는 최종 메시지 다이제스트를 자신의 개인 서명키로 암호화 하여 이중서명을 생성함

<문제 해설>
이중 서명은 SET에서 도입된 기술이다.
[해설작성자 : Melbourne]

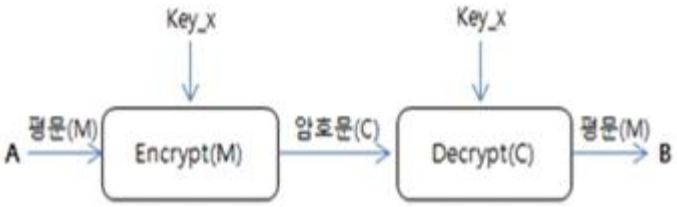
79. 인증서 상태를 관리하고 있는 서버는 유효성 여부에 관하이 답을 즉시 보내주는 프로토콜은?

① CRL ② OCSP
③ OCRL ④ SSL

<문제 해설>
1. CRL(Certificate Revocation List) : 인증서 폐기목록
2. OCSP (온라인 인증서 상태 확인 프로토콜): CRL 다운없이 인증서의 상태 확인 /good, revoked, unknown
전자서명 인증서 폐기 목록의갱신 주기성 문제를 해결하기 위해 폐지/효력 정지 상태를 파악하여 사용자가 실시간으로 인증서를 검증할수 있는 프로토콜
[해설작성자 : 해설을 보세요]

80. 그림은 사용자 A가 사용자 B에게 암호문을 전달하는 과정이다. Key_x와 Key_y가 동일하다면 이에 대한 설명으로 옳

지 않은 것은?



① n명의 사용자가 암호화 시스템에 참여하는 경우 n(n-1)/2)개의 키가 필요하다.
② 암호화 시스템 사용자가 1명씩 증가할 때마다 키의 개수는 기하급수적으로 증가한다.
③ 동일한 키를 사용함으로써 비밀성 및 부인방지의 기능을 제공한다.
④ Decrypt(C)의 알고리즘은 Encrypt(M) 알고리즘의 역순이다.

<문제 해설>
대칭키과 공개키 암호화방식의 차이를 묻는문제

대칭키
- 키문배방식의 문제가 있음
- 기밀성을 제공하나, 무결성/인증/부인방지 를 보장하지 않음
- 속도가 매우 빠름

공개키
- 키분배 필요 X,
- 기밀성/인증/부인방지 기능 제공
- 속도가 비교적 느림
[해설작성자 : 맞나?아닌가?]

5과목 : 정보보안 관리 및 법규

81. 정보통신망법에 따라 정보통신서비스 제공자 등은 중요 정보에 대해서는 안전한 암호알고리즘으로 암호화하여 저장하여야 한다. 다음중 법령에 따른 필수 암호화 저장 대상이 아닌것은?

① 주민등록번호 ② 운전면허번호
③ 핸드폰번호 ④ 계좌번호

<문제 해설>
비밀번호는 복호화 되지 않도록 일방향 암호화해서 저장
다음 각 호의 정보를 안전한 암호알고리즘으로 암호화해서 저장해야한다.

주민등록번호
여권번호
운전면허번호
외국인등록번호
신용카드번호
계좌번호
바이오정보
[해설작성자 : 한비로]

82. 「개인정보 보호법 상 용어 정의로 가장 옳지 않은 것은?

① 개인정보: 살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보
② 정보주체: 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람
③ 처리: 개인정보의 수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정, 복구, 이용, 제공, 공개, 파기(破棄), 그 밖에 이와 유사한 행위
④ 개인정보관리자: 업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인

<문제 해설>
1. "개인정보"란
살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보(해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다.
2. "처리"란
개인정보의 수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정(訂正), 복구, 이용, 제공, 공개, 파기(破棄), 그 밖에 이와 유사한 행위를 말한다.
3. "정보주체"란
처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람을 말한다.
4. "개인정보파일"이란
개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물(集合物)을 말한다.
5. "개인정보처리자"란
업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등을 말한다.
6. "공공기관"이란
가. 국회, 법원, 헌법재판소, 중앙선거관리위원회의 행정사무를 처리하는 기관, 중앙행정기관(대통령 소속 기관과 국무총리 소속 기관을 포함한
다) 및 그 소속 기관, 지방자치단체
나. 그 밖의 국가기관 및 공공단체 중 대통령령으로 정하는 기관
[해설작성자 : 해설을 보세요]

83. 다음 중 빈 칸에 들어갈 용어의 순서가 가장 적합한 것은?

프로젝트의 범위 · 설정 · 기획 → (㉠) →(㉡) → (㉢) → 프로젝트의 수행 테스트 및 유지 보수

① ㉠ 복구계획 수립, ㉡ 복구전략 개발, ㉢ 사업영향평가
② ㉠ 복구전략 개발, ㉡ 복구계획 수립, ㉢ 사업영향평가
③ ㉠ 사업영향평가, ㉡ 복구계획 수립, ㉢ 복구전략 개발
④ ㉠ 사업영향평가, ㉡ 복구전략 개발, ㉢ 복구계획 수립

<문제 해설>
업무연속성 계획 순서

1. 프로젝트 범위 설정 및 기획
2. 사업영향평가(BIA) - 필요한 평가자료 수립, 취약성 평가 수행, 편집된 정보분석, 문서화&권고문 작성
3. 복구전략개발
4. 복구계획수립
5. 프로젝트 수행 및 테스트 유지보수

[해설작성자 : 보안기사괜히접수했다]

84. 정보보호 관리체계 인증제도에 대한 설명으로 가장 적절하지 않은 것은?

① 인증대상은 임의신청자와 의무대상자로 구분되며, 인공의무대상자가 인증을 받지 않으면 과태료 3천만원이 부과된다.
② 임의신청자의 경우 인증범위를 신청기관이 정하여 신청할 수 있으며, 심사기준 및 심사절차는 의무대상자 심사와 동일하다.
③ 정보통신망법 제46조에 따른 집적정보통신시설 사업자는 의무대상자이다.
④ 전년도 직전 3개월간 정보통신서비스 일일평균 이용자 수가 10만명 이상인 자는 대상이다.

<문제 해설>
전년도 매출액 100억이상 또는 전년도말 기준 직전 3개월간 일일평균 이용자수 100만명 이상인 자 대상
[해설작성자 : 보안기사괜히접수했다]

85. OECD 개인정보보안 8원칙에 포함되지 않는 것은 무엇인가?

① 이용제한의 원칙
② 정보 정확성의 원칙
③ 비공개의 원칙
④ 안전성 확보의 원칙

<문제 해설>
01.개인정보보호 8원칙 (OECD 가이드라인)
1) 수집제한의 원칙
개인정보를 수집할 때는 정보 주체에게 알리거나 동의를 구해야 합니다.
2) 정보내용의 원칙
개인정보는 사용목적에 부합해야 하고 목적에 필요한 범위 내에서 유지되어야 합니다.
3) 목적명확화의 원칙
개인 정보를 수집할 때에는 그 수집목적이 명확하게 제시되어야 합니다
4) 이용(사용)제한의 원칙
개인 정보는 수집 당시의 목적 이외에 용도로 누출되거나 사용되어서는 안됩니다.
5) 안전보호의 원칙
개인 정보의 유출 위험에 대비하여 합리적인 보안 장치를 마련해야 합니다
6) 공개의 원칙
개인 정보에 관한 개발, 운용 및 정책에 관해서 일반적인 공개정책을 취해야 합니다
7) 개인 참가의 원칙
정보 주체인 개인은 쉽게 자기 정보를 열람할 수 있어야 하며, 자신의 정보에 대해 이의를 제기하거나 삭제, 정정, 보완, 수정을 청구할 수 있어야 합니다
8) 책임의 원칙
정보 관리자는 위의 원칙들이 지켜지도록 필요한 제반 조치를 취할 책임이 있습니다

[해설작성자 : comcbt.com 이용자]

86. 다음 지문이 설명하는 정보보호 관련 제도는?

민간업체 등에서 개발한 정보보호시스템을 국제표준인 ISO 15408 및 ISO 18045를 이용하여 보안기능에 대한 안정성과 신뢰성을 보증함으로써 사용자들이 안심하고 정보보호시스템 을 사용할 수 있도록 지원하는 제도

① 정보보호제품 평가 · 인증 제도
② 정보보호 관리체계 인증 제도
③ 보안적합성 검증 제도
④ 암호모듈 검증 제도

<문제 해설>
공통평가기준(Common Criteria, 약어 CC)
보통 CC인증이라고 불리우며
컴퓨터 보안을 위한 국제 표준, ISO 15408라고도 불린다.

정보보호제품에 구현된 보안기능이 평가신청한 평가보증등급 수준에 부합하는지 검증함으로써,
사용자가 자신의 보안 요구를 충족하는 IT 제품 선택을 지원. 특히, 우리나라는 국가정보원이 필요성을 인정하는 정보보호제품의 경우 국가·공공기관에서 CC 인증제품을 도입하도록 하는 등 CC 인증제품을 활용
[해설작성자 : 맞나?아닌가?]

87. 개인정보보호법 제3조(개인정보 보호 원칙)에 대한 내용 중 틀린 것은?

① 개인정보처리자는 개인정보의 처리 목적을 명확하게 하여야 하고 그 목적에 필요한 범위에서 최소한의 개인정보만을 적법하고 정당하게 수집하여야 한다.
② 개인정보처리자는 개인정보의 처리 목적에 필요한 범위에서 적합하게 개인정보를 처리하여야 하며, 그 목적 외의 용도로 활용하여서는 아니 된다.
③ 개인정보처리자는 개인정보의 처리 목적에 필요한 범위에서 개인정보의 기밀성, 무결성 및 신뢰성이 보장되도록 하여야 한다.
④ 개인정보처리자는 개인정보의 처리 방법 및 종류 등에 따라 정보주체의 권리가 침해받을 가능성과 그 위험 정도를 고려하여 개인정보를 안전하게 관리하여야 한다.

<문제 해설>
제3조(개인정보 보호 원칙)
① 개인정보처리자는 개인정보의 처리 목적을 명확하게 하여야 하고 그 목적에 필요한 범위에서 최소한의 개인정보만을 적법하고 정당하게 수집하여야 한다.
② 개인정보처리자는 개인정보의 처리 목적에 필요한 범위에서

적합하게 개인정보를 처리하여야 하며, 그 목적 외의 용도로 활용하여서는 아니 된다.
③ 개인정보처리자는 개인정보의 처리 목적에 필요한 범위에서 개인정보의 정확성, 완전성 및 최신성이 보장되도록 하여야 한다.
④ 개인정보처리자는 개인정보의 처리 방법 및 종류 등에 따라 정보주체의 권리가 침해받을 가능성과 그 위험 정도를 고려하여 개인정보를 안전하게 관리하여야 한다.
⑤ 개인정보처리자는 개인정보 처리방침 등 개인정보의 처리에 관한 사항을 공개하여야 하며, 열람청구권 등 정보주체의 권리를 보장하여야 한다.
⑥ 개인정보처리자는 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 한다.
⑦ 개인정보처리자는 개인정보의 익명처리가 가능한 경우에는 익명에 의하여 처리될 수 있도록 하여야 한다.
⑧ 개인정보처리자는 이 법 및 관계 법령에서 규정하고 있는 책임과 의무를 준수하고 실천함으로써 정보주체의 신뢰를 얻기 위하여 노력하여야 한다.
[해설작성자 : 한비로 두비로 세비로]

88. 다음은 개인정보의 안전성 확보조치 기준에서의 인터넷 홈페이지 취약점 점검과 관련한 설명이다. 옳은 것들을 모두 고른 것은?

a. 인터넷 홈페이지를 통해 고유식별정보를 처리하는 개인정보처리자는 해당 인터넷 홈페이지에 대해 연 1회 이상 취약점을 점검하고 필요한 보완 조치를 하여야 한다.
b. 인터넷 홈페이지의 취약점 점검은 개인정보처리자의 자체인력, 보안업체 등을 활용할 수 있으며, 취약점 점검은 상용도구, 공개용 도구, 자체제작 도구 등을 사용할 수 있다.
c. 웹 취약점 점검과 함께 정기적으로 웹쉘 등을 점검하고 조치하는 경우 취급 중인 개인정보가 인터넷 홈페이지를 통 해 열람권한이 없는 자에게 공개되거나 유출되는 위험성을 더욱 줄일 수 있다.

① a, b ② b, c
③ a, c ④ a, b, c

<문제 해설>
제6조(접근통제)
④ 고유식별정보를 처리하는 개인정보처리자는 인터넷 홈페이지를 통해 고유식별정보가 유출·변조·훼손되지 않도록 연 1회 이상 취약점을 점검하고 필요한 보완 조치를 하여야 한다..

4-1. 인터넷 홈페이지를 통해 고유식별정보(주민등록번호, 운전면허번호, 외국인등록번호, 여권번호)를 처리하는 개인정보처리자는 고유식별정보가 유출·변조·훼손되지 않도록해당 인터넷 홈페이지에 대해 연 1회 이상 취약점을 점검하여야 하며, 그 결과에 따른 개선 조치를 하여야 한다.
4-2 인터넷 홈페이지의 취약점 점검 시에는 기록을 남겨 책임추적성 확보 및 향후 개선조치 등에 활용할 수 있도록 할 필요가 있다.
4-3 인터넷 홈페이지의 취약점 점검은 개인정보처리자의 자체인력, 보안업체 등을 활용할 수 있으며, 취약점 점검은 상용 도구, 공개용 도구, 자체 제작 도구 등을 사용할 수 있다
4-4 기술과 서비스 발전에 따라 시스템 등에 대한 신규 취약점은 계속적으로 발생하고있으며, 정기적인 취약점 점검 및 개선조치를 통하여 개인정보 유출을 예방하는 등 적극적인 보호활동을 권장한다.
[해설작성자 : 한비로]

89. 위험관리 절차를 순서대로 배열한 것은?

㉠ 자산식별	㉡ 정보보호계획 수립
㉢ 정보보호대책 수립	㉣ 위험 분석 및 평가
㉤ 주기적 재검토	

① ㉠ - ㉡ - ㉢ - ㉣ - ㉤
② ㉠ - ㉣ - ㉢ - ㉡ - ㉤
③ ㉠ - ㉡ - ㉣ - ㉢ - ㉤
④ ㉠ - ㉣ - ㉡ - ㉢ - ㉤

<문제 해설>
자산식별 -> [취약/위험/가치/의존도/보안대책]평가,분석 -> 대책 선택 -> 위험[수용 or 계획수립] -> 지속적위험관리
[해설작성자 : 한비로 두비로 세비로]

90. 「개인정보 보호법」에서 규정하고 있는 개인정보 중 민감정 보에 해당하지 않는 것은?
① 주민등록번호
② 노동조합 · 정당의 가입·탈퇴에 관한 정보
③ 건강에 관한 정보
④ 사상 · 신념에 관한 정보

<문제 해설>
민감정보
①사상·신념
②노동조합·정당의 가입·탈퇴
③정치적 견해
④건강, 성생활 등에 관한 정보
⑤그 밖에 정보주체의 사생활을 현저히 침해할 우려가 있는 개인정보로서 대통령령이 정하는 정보
[해설작성자 : 보안기사괜히접수했다]

91. 현재 존재하는 위험이 조직에서 수용할 수 있는 수준을 넘어 선다면, 이 위험을 어떤 방식으로든 처리해야 된다. 다음의 지문이 설명하고 있는 위험 처리 방식은?

보험이나 외주 등으로 위험 처리에 소요될 잠재적 비용을 제 3자에게 이전하거나 할당하는 위험처리 방식

① 위험 수용 ② 위험 감소
③ 위험 회피 ④ 위험 전가

<문제 해설>
위험을 다른 쪽으로 돌리므로서 피해를 줄일 수 있다..= 위험전가

[해설작성자 : Melbourne]

92. 다음의 보기에서 정보통신기반보호법에서 규정된 주요정보통신기반시설 지정 시 고려사항이 아닌 것은?
① 당해 정보통신기반시설을 관리하는 기관이 수행하는 업무의 국가사회적 중요성
② 다른 정보통신기반시설과의 상호연계성
③ 침해사고의 발생가능성 또는 그 복구의 용이성
④ 시설이 취급하고 있는 개인정보의 규모

<문제 해설>
제3장 제8조 주요정보통신기반시설의 지정
1. 해당 정보통신기반시설을 관리하는 기관이 수행하는 업무의 국가사회적 중요성
2. 제1호에 따른 기관이 수행하는 업무의 정보통신기반시설에 대한 의존도
3. 다른 정보통신기반시설과의 상호연계성
4. 침해사고가 발생할 경우 국가안전보장과 경제사회에 미치는 피해규모 및 범위
5. 침해사고의 발생가능성 또는 그 복구의 용이성
[해설작성자 : 한비로]

93. 다음은 개인정보보호법에 따른 개인정보의 파기에 관하여 설명한 것이다. 옳은 것은?
① 개인정보처리자는 처리 목적의 달성여부와 관계없이 동의 기간이 경과해야만 개인정보를 파기할 수 있다.
② 개인정보처리자는 동의기간이 경과하더라도 처리목적이 달성되지 못한 경우에는 개인정보를 계속 이용할 수 있다.
③ 개인정보처리자는 개인정보를 파기해야 하는 사유가 발생했을 때에는 정당한 사유가 없는 한 5일 이내에 개인정보를 파기해야 한다.
④ 복원이 불가능한 방법이란 미래에 개발될 기술도 고려하여 파기 후 개인정보의 복구 가능성을 원천 차단한 방법을 의미한다.

<문제 해설>
제10조(개인정보의 파기방법 및 절차)
① 개인정보처리자는 개인정보의 보유 기간이 경과하거나 개인정보의 처리 목적 달성, 해당 서비스의 폐지, 사업의 종료 등 그 개인정보가 불필요하게 되었을 때에는 정당한 사유가 없는 한 그로부터 5일 이내에 그 개인정보를 파기하여야 한다..
② 제16조제1항제1호의 '복원이 불가능한 방법'이란 현재의 기술수준에서 사회통념상 적정한 비용으로 파기한 개인정보의 복원이 불가능하도록 조치하는 방법을 말한다..
③ 개인정보처리자는 개인정보의 파기에 관한 사항을 기록·관리하여야 한다..
④ 개인정보 보호책임자는 개인정보 파기 시행 후 파기 결과를 확인하여야 한다..
[해설작성자 : 한비로]

94. 개인정보처리자가 개인정보의 수집 시 정보주체의 동의를 받지 않아도 되는 경우로 가장 적절한 것은?
① 개인정보취급 방침에 명시한 경우
② 경제적, 기술적인 사유로 통상적인 동의를 받는 것이 뚜렷하게 곤란한 경우
③ 법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우
④ 요금 부과를 위해 필요한 경우

<문제 해설>
1. 정보주체의 동의를 받은 경우
==========
2. 법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우
3. 공공기관이 법령 등에서 정하는 소관 업무의 수행을 위하여 불가피한 경우
4. 정보주체와의 계약의 체결 및 이행을 위하여 불가피하게 필요한 경우
5. 정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소불명 등으로 사전 동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우
6. 개인정보처리자의 정당한 이익을 달성하기 위하여 필요한 경우로서 명백하게 정보주체의 권리보다 우선하는 경우. 이 경우 개인정보처리자의 정당한 이익과 상당한 관련이 있고 합리적인 범위를 초과하지 아니하는 경우에 한한다.
[해설작성자 : 한비로]

95. 다음 보기가 설명하는 위험분석 방법은?

- 어떤 사건도 기대대로 발생하지 않는다는 사실에 근거하여 일정 조건 하에 위협에 대한 발생 가능한 결과들을 추정하는 방법 - 적은 정보를 가지고 전반적인 가능성을 추론할 수 있고 위험분석과 관리층 간의 원활한 의사소통을 가능하게 한다. 그러나 발생 가능한 사건의 이론적인 추측에 불과하고 정확도, 완성도, 이용기술의 수준 등이 낮을 수 있음.

① 과거자료 분석법
② 확률 분포법
③ 델파이법
④ 시나리오법

<문제 해설>
과거자료 분석법 : 정량적 위험분석
과거의 자료를 통하여 위험 발생 가능성을 예측하는 방법, 는 과거에 대한 자료가 많으면 많을수록 분석의 정확도가 높음

확률분포법 : 정량적 위험분석
미지의 사건을 확률적으로 편차를 이용하여 최저, 보통, 취고 위험 평가를 예측하는 방법이다..

델파이기법 : 정성적 위험분석
전문가 집단에게 설문조사를 실시하여 집단의 의견을 정리하는 분석방법

시나리오법 : 정성적 위험분석

어떤 사실도 기대대로 발생하지 않는다는 조건하에서 특정 시나리오를 통한 위협에 대한 발생 가능한 결과를 우선순위로 도출해 내는 방법
[해설작성자 : 한비로]

96. 다음 지문은 정보통신망법상 전자문서의 정의 규정이다. ( ) 에 적합한 용어를 찾으시오.

> '전자문서'란 컴퓨터 등 정보처리능력을 가진 장치에 의하여 (A)인 형태로 작성되어 송수신되거나 저장된 문서형식의 자료로서 (B)된 것을 말한다.

① A : 전기적, B: 정형화
② A : 전자적, B: 표준화
③ A : 전기적, B : 표준화
④ A : 전자적, B: 정형화

<문제 해설>
[정보통신망 이용촉진 및 정보보호 등에 관한 법률 제2조 제5호]
전자문서"란 컴퓨터 등 정보처리능력을 가진 장치에 의하여 [전자적]인 형태로 작성되어 송수신되거나 저장된 문서형식의 자료로서 [표준화]된 것을 말한다.
[해설작성자 : 한비로]

97. 다음은 정보보호 정책 및 조직과 관련한 설명이다. 옳지 않은 것은?

① 조직이 수행하는 모든 정보보호 활동의 근거를 포함할 수 있도록 정보보호정책을 수립해야 하며, 이러한 정책은 조직과 관련한 것이므로 국가나 관련 산업에서 정하는 정보보호 관련 법, 규제를 고려할 필요는 없다.
② 조직에 미치는 영향을 고려하여 중요한 업무, 서비스, 조직, 자산 등을 포함할 수 있도록 정보보호 관리체계 범위를 설정하고 범위 내 모든 자산을 식별하여 문서화하여야 한다.
③ 정보보호 관리체계 수립 및 운영 등 조직이 수행하는 정보보호 활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 체계를 수립해야 한다.
④ 최고경영자는 조직의 규모, 업무 중요도 분석을 통해 정보보호 관리체계의 지속적인 운영이 가능하도록 정보보호 조직을 구성하고 정보보호 관리체계 운영 활동을 수행하는데 필요한 자원을 확보하여야 한다.

<문제 해설>
ISMS 점검목록
1. 경영진의 참여
경영자는 정보보호 및 개인정보보호 관리체계의 수립과 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 체계를 수립하여 운영하여야 한다.

2. 최고책임자의 지정
최고경영자는 정보보호 업무를 총괄하는 정보보호 최고책임자와 개인정보보호 업무를 총괄하는 개인정보보호 책임자를 예산·인력 등 자원을 할당할 수 있는 임원급으로 지정하여야 한다.

3. 조직 구성
최고경영자는 정보보호와 개인정보보호의 효과적 구현을 위한 실무조직, 조직 전반의 정보보호와 개인정보보호 관련 주요 사항을 검토 및 의결할 수 있는 위원회, 전사적 보호활동을 위한 부서별 정보보호와 개인정보보호 담당자로 구성된 협의체를 구성하여 운영하여야 한다.

4. 범위 설정
조직의 핵심 서비스와 개인정보 처리 현황 등을 고려하여 관리체계 범위를 설정하고, 관련된 서비스를 비롯하여 개인정보 처리 업무와 조직, 자산, 물리적 위치 등을 문서화하여야 한다.

5. 정책 수립
정보보호와 개인정보보호 정책 및 시행문서를 수립·작성하며, 이때 조직의 정보보호와 개인정보보호 방침 및 방향을 명확하게 제시하여야 한다..또한 정책과 시행문서는 경영진 승인을 받고, 임직원 및 관련자에게 이해하기 쉬운 형태로 전달하여야 한다.
>> 5-1. 정책의 유지관리 : 정보보호 및 개인정보보호 관련 정책과 시행문서는 법령 및 규제, 상위 조직 및 관련 기관 정책과의 연계성, 조직의 대내외 환경변화 등에 따라 주기적으로 검토하여 필요한 경우 제·개정하고 그 내역을 이력관리하여야 한다.

6. 자원 할당
최고경영자는 정보보호와 개인정보보호 분야별 전문성을 갖춘 인력을 확보하고, 관리체계의 효과적 구현과 지속적 운영을 위한 예산 및 자원을 할당하여야 한다.
[해설작성자 : 한비로]

98. 다음은 정보보호 교육과 관련한 설명이다. 옳지 않은 것은?

① 교육의 시기, 기간, 대상, 내용, 방법 등의 내용이 포함된 연간 정보보호 교육 계획을 수립하면서, 대상에는 정보보호 관리체계 범위 내 임직원을 포함시켜야 하고, 외부용역 인력은 제외해도 무방하다.
② 교육에는 정보보호 및 정보보호 관리 체계 개요, 보안사고 사례, 내부 규정 및 절차, 법적 책임 등의 내용을 포함 하고 일반 임직원, 책임자, IT 및 정보보호 담당자 등 각 직무별 전문성 제고에 적합한 교육내용 및 방법을 정하여야 한다.
③ 연 1회 이상 교육을 시행하고 정보보호 정책 및 절차의 중 대한 변경, 조직 내·외부 보안사고 발생, 관련 법규 변경 등의 사유가 발생할 경우 추가 교육을 수행해야 한다.
④ 교육 내용에는 구성원들이 무엇을 해야 하며, 어떻게 할 수 있는지에 대한 것을 포함해야 하며, 가장 기본적인 보안 단계의 실행에서부터 좀 더 고급의 전문화된 기술에 이르기까지 다양한 단계로 나누어 구성할 수 있다.

<문제 해설>
정보보호 교육에 있어서는 내부인원은 당연한거고, 같이 일하게 되는 외부 인원들 또한 포함된다.
[해설작성자 : Melbourne]

99. 다음 중 ISMS(Information Security Management System)

의 각 단계에 대한 설명으로 옳은 것은?

① 계획 : ISMS 모니터링과 검토
② 조치 : ISMS 관리와 개선
③ 수행 : ISMS 수립
④ 점검 : ISMS 구현과 운영

<문제 해설>
계획 - ISMS 수립
↓
수행 - ISMS 구현과 운영
↓
점검 - ISMS 모니터링과 검토
↓
조치 - ISMS 관리와 개선
[해설작성자 : 한비로]

100. 국가안전보장에 중대한 영향을 미치는 주요정보통신기반시설에 대한 보호대책의 미흡으로 국가안전보장이나 경제사회 전반에 피해가 우려될 수 있으므로 기반시설을 지정하여야 한다. 다음 중 주요정보통신기반시설이 아닌 것은 무엇인가?

① 전력, 가스, 석유 등 에너지 · 수자원시설
② 인터넷포털, 전자상거래 등 인터넷시설
③ 도로·철도·지하철·공항·항만 등 주요 교통시설
④ 방송중계 국가지도통신망 시설

<문제 해설>
[국가기반시설 지정 대상]
1. 에너지
전력, 석유, 가스
2. 정보통신
국가기간망, 통신구, 주요전산시스템
3. 교통수송
철도, 항공, 화물, 도로, 항만
4. 금융
주요 금융시스템
5. 산업
방위산업체, 산업단지, 철강, 원자제 및 반도체 전자, 자동차 생산업체
6. 의료, 보건
의료서비스, 전염병 관리
7. 원자력
8. 건설 환경
생활폐기물 수집 운반 소각시설 폐수처리장
9. 식 용수
용수, 식수
[해설작성자 : 한비로]

본 해설집의 저작권은 www.comcbt.com에 있으며
카페, 블로그 등의 업로드 및 개인적 활용 이외에
문서의 수정 및 DB 저장, 기타 금전적 이익을 취하는 일체의 행위를 금지 합니다.

전자문제집 CBT 홈페이지 : www.comcbt.com
기출문제 및 해설집 다운로드 : www.comcbt.com/xe
전자문제집 CBT 앱(구글플레이) : [다운로드]

전자문제집 CBT란? 인터넷으로 종이 없이 문제를 풀고 자동채점하는 프로그램으로 워드, 컴활, 기능사 등의 상설검정에서 사용하는 실제 프로그램 방식입니다.
해설을 제공하며 PC 버전 및 모바일 버전 완벽 연동
교사용/학생용 관리기능도 제공합니다.

오답 및 오탈자가 수정된 최신 자료와 해설은 전자문제집 CBT에서 확인하세요.

1	2	3	4	5	6	7	8	9	10
④	①	③	②	③	②	③	②	②	①
11	12	13	14	15	16	17	18	19	20
②	④	③	②	④	④	③	②	②	③
21	22	23	24	25	26	27	28	29	30
②	②	①	④	③	①	④	②	④	④
31	32	33	34	35	36	37	38	39	40
①	①	④	②	②	④	④	②	①	①
41	42	43	44	45	46	47	48	49	50
①	④	①	②	②	①	②	③	④	④
51	52	53	54	55	56	57	58	59	60
④	①	①	③	①	③	④	④	②	②
61	62	63	64	65	66	67	68	69	70
①	②	②	①	①	①	④	③	③	②
71	72	73	74	75	76	77	78	79	80
④	②	②	③	②	②	④	③	②	③
81	82	83	84	85	86	87	88	89	90
③	④	④	④	③	①	③	④	②	①
91	92	93	94	95	96	97	98	99	100
④	④	③	③	④	②	①	①	②	②